Author: Andrey Pautov. Published on Medium

Malicious Activity as a Statistical Signal: A Detection Engineering Analysis of Anomaly-Based Detection

An evidence-based examination of the hypothesis that suspicious and malicious activity produces measurable deviations from normal behaviour — with documented examples from real APT campaigns, specific log sources, security device detection capabilities, and detection engineering patterns.

By Andrey Pautov — April 2026

> ***Epistemic labels used throughout:*** *[Documented] = the cited source explicitly states this fact or detection opportunity. [Inferred] = the source documents the underlying tradecraft; the detection derivation is the author's reasoned conclusion. Claims without a label are general statements with consensus support in the cited literature.*

Table of Contents

1. The Hypothesis — Scope and Definitions
2. Taxonomy of Anomaly Types
3. Mapping Anomalies to the ATT&CK Lifecycle
4. Evidence Register: Real APT Campaigns and Documented Anomaly Patterns
   - 4.11 CISA AA22-277A — Impacket Lateral Movement in Defense Industrial Base Compromise (2022)
5. Detection by Log Source and Security Device
6. Credential-Based Attacks: Detection Engineering Deep Dive
7. How Attackers Suppress Anomaly Visibility
8. Detection Engineering Patterns and Logic Examples
9. Implementation Guidance

10. Conclusion

11. References

---

1. The Hypothesis — Scope and Definitions

The claim that malicious activity creates detectable anomaly patterns underpins UEBA platforms, ML-based SIEM analytics, network traffic analysis tools, and a large portion of behavioural detection engineering practice.

The hypothesis is **substantially true, but bounded**. It holds for specific attack phases and specific categories of malicious action. It fails — predictably and structurally — for others. Understanding *when* and *why* it fails is operationally more valuable than treating it as a universal principle.

1.1 Definitions

Anomaly. NIST SP 800-94 defines anomaly-based intrusion detection as the comparison of normal activity profiles against observed events to identify significant deviations [1]. In operational terms, an anomaly is a measurable deviation from one or more baselines: an entity baseline (this user, this host), a peer baseline (users in this role, hosts in this class), a temporal baseline (activity at this time of day), a relationship model (who normally communicates with whom), or an event-sequence model (what normally follows what).

Point anomaly. A single data instance that is anomalous relative to the rest of the data (Chandola et al., 2009) [2]. Example: a workstation that has never generated outbound DNS queries to high-entropy subdomain strings doing so for the first time.

Contextual anomaly. An instance that is anomalous only in a specific context [2]. Example: `ntdsutil` executed by an administrator account is routine on a domain controller used for backup and anomalous on a developer workstation.

Collective anomaly. A collection of related instances that is anomalous together, even if each individual instance is not [2]. Example: in the SUNBURST campaign, no single DNS query to `avsvmcloud[.]com` subdomains was inherently suspicious. The collective anomaly emerged in two distinct phases: first, a 12–14 day dormancy window during which the implant performed only local environment checks and generated no C2 traffic; second, once dormancy ended, periodic callback queries to actor-controlled DNS infrastructure encoding victim-specific data in subdomain labels. The dormancy phase itself produces no observable signal; the anomaly only becomes detectable once callback activity begins. [3]

Malicious-behaviour correlation. The analytical step that links an observed anomaly to an attacker goal, technique, or intrusion stage. An anomaly is not a verdict — it is evidence. A detection becomes operationally useful when that evidence is correlated with asset context, identity state, companion telemetry, or known adversary tradecraft.

1.2 The Central Tension

In a typical enterprise environment, the ratio of malicious events to benign events approaches zero. A detection system with 99% precision will still produce thousands of false positives daily if it processes millions of benign events. This is the base-rate fallacy applied to security operations; NIST SP 800-94 identified it explicitly: "complex environments are difficult to model accurately, and benign deviations can trigger large numbers of false positives" [1].

Anomaly detection produces operational value only when the baseline is tight, the signal is stable, and the anomaly is rare in legitimate traffic. Where those conditions hold, the approach is useful. Where they do not, false positive rates erode analyst confidence faster than they generate detections.

---

2. Taxonomy of Anomaly Types

The taxonomy below draws on Chandola et al. [2], NIST SP 800-94 [1], Microsoft MSTIC publications [4][5][6], Mandiant reporting [7][8][9], CISA/NSA joint advisories [10][11], and the Australian Cyber Security Centre (ACSC) [12].

Volumetric — Unusual absolute volume of data or events vs. entity baseline. Telemetry: NetFlow, firewall egress, DNS, file/object access, cloud audit. Approach: rolling threshold + percentile baseline (Z-score, IQR, moving average). Stability: high for exfiltration/impact stages; lower on shared infrastructure. FP risk: Medium.
Examples:
- A finance user who normally uploads 20–50 files per day suddenly downloads 8,000 SharePoint documents in 40 minutes.
- A database server with stable nightly replication begins sending 12 GB of outbound traffic to an external IP at 03:12, far above its normal egress baseline.
- A workstation that usually makes fewer than 200 DNS requests per hour suddenly generates 9,000 queries, including many high-entropy subdomains.
- A cloud service account that typically reads a few dozen objects per day suddenly accesses 30,000 S3 objects in one session.

- A file server that normally changes 1–2 GB of data daily suddenly shows mass file modifications and deletions consistent with ransomware impact.

Frequency / Rate — Unusual rate of repeated events within a time window. Telemetry: auth logs, API logs, process start logs, DNS. Approach: count-by-entity over rolling window; Poisson model. Stability: high when concentrated in one source; weak when distributed. FP risk: Medium.
Examples:
- A single user account generates 45 failed VPN logins in 6 minutes, far above its normal authentication rate.
- One API client that typically makes 2–3 requests per minute suddenly sends 1,200 token validation requests in 10 minutes.
- A workstation that usually launches a browser a few times per hour suddenly starts 300 PowerShell processes in 15 minutes.
- A host that normally performs low-volume name resolution suddenly issues hundreds of DNS queries per minute to many rare domains.
- A service account that usually accesses one mailbox at a time suddenly performs repeated read operations across dozens of mailboxes in a short window.

Temporal — Activity at unusual times relative to entity, business cycle, or service baseline. Telemetry: auth logs, SaaS audit, admin actions, EDR. Approach: working-hours baseline; time-series decomposition; seasonality models. Stability: medium; highly context-dependent. FP risk: Medium–High.
Examples:
- An HR employee who normally logs in between 08:00–17:00 starts downloading sensitive employee records at 02:43 on a Sunday.
- A SaaS admin account that is typically active only during local business hours performs privilege changes at 03:10.
- A developer laptop that usually shows weekday activity suddenly initiates code repository access and cloud console actions during a national holiday.
- A server management account that normally runs scheduled maintenance at 01:00–02:00 begins executing admin actions at an unusual afternoon hour outside its normal service window.
- A user with a stable daytime pattern starts authenticating from the same device every night for several consecutive days, outside their historical baseline.

Peer-Group — Entity deviates materially from its peer cohort (same role, department, host class). Telemetry: identity logs, HR data, endpoint inventory, SaaS access. Approach: clustering (K-Means, TF-IDF), peer distribution percentiles. Stability: medium–high when peer groups are cleanly defined. FP risk: Medium.
Examples:
- One finance employee accesses source code repositories and DevOps dashboards that no one else in the

finance peer group normally uses.
- A single workstation in the same Windows server class begins spawning developer tools and compression utilities, unlike its peer servers.
- One sales user downloads 15 times more CRM records than others in the same department over the same week.
- A service account in a group of low-privilege automation accounts suddenly begins calling privileged admin APIs that its peers never invoke.
- One employee in a peer group of standard Microsoft 365 users starts creating mailbox forwarding rules and performing eDiscovery-like searches, unlike comparable users with the same role.

Sequence — Events occur in an unusual order relative to normal operational paths. Telemetry: process trees, auth chains, API sequences, session logs. Approach: finite-state models, Markov chains, LSTM, provenance graphs. Stability: high for stable server roles; lower for developer environments. FP risk: Medium.
Examples:
- A user authenticates to a SaaS tenant, creates a new OAuth app, grants high-risk permissions, and then performs bulk data access in a sequence not seen in normal admin workflows.
- On a server, `powershell.exe` spawns `rundll32.exe`, which then launches a network connection to an external host — an execution chain that deviates from the usual parent-child order.
- A mailbox access session shows inbox rule creation before any normal interactive user activity, followed immediately by message forwarding and deletion operations.
- A cloud workflow shows snapshot creation, privilege modification, and object export in an order that does not match standard backup or maintenance procedures.
- A workstation process tree shows Office opening a script interpreter, then a credential access tool, then an archive utility — an event sequence inconsistent with normal user productivity flows.

Graph / Relationship — Unexpected edges, bridges, or paths in identity, network, or resource graphs. Telemetry: Active Directory, IAM, SaaS permissions, NetFlow. Approach: graph analytics, community detection, link-prediction scoring. Stability: high for privilege-path changes; moderate for network paths. FP risk: Medium.
Examples:
- A low-privilege user is suddenly added to a group that creates a new privilege path to domain admin through nested Active Directory memberships.
- An IAM role that normally accesses only one application is granted trust relationships that connect it to multiple high-value cloud resources it never touched before.
- A workstation begins communicating with a server segment that is normally reachable only by backup or management systems, creating a new network edge outside its usual community.
- A SaaS account that historically had no relationship to executive mailboxes suddenly gains delegated access

to several senior leadership accounts.
- A service account becomes the bridge between two previously separate environments by authenticating to both the on-prem domain and cloud admin plane, creating an unusual cross-environment path.

Geographic / ASN — Access from new, implausible, or inconsistent locations or network providers. Telemetry: IdP logs, VPN, SaaS, cloud console. Approach: geo-baseline + impossible-travel logic + ASN peer history. Stability: medium alone; stronger with enrichment. FP risk: High if used alone.
Examples:
- A user who has only ever logged in from Israel suddenly authenticates to Microsoft 365 from Vietnam and then accesses sensitive SharePoint content minutes later.
- An administrator signs in from a residential ISP in the morning and then appears from a cloud-hosting ASN in another country 25 minutes later, triggering impossible-travel logic.
- A service account that normally uses one fixed corporate VPN egress suddenly accesses the cloud console from a consumer mobile network ASN.
- A SaaS account with a stable history of logins from one city begins showing repeated access from multiple distant countries over two days.
- A privileged user who normally connects only through a known enterprise VPN starts logging in from a newly observed anonymisation provider or VPS-hosting ASN.

Identity / Access — Unusual auth properties, factor changes, app consents, or token behaviour. Telemetry: IdP, MFA, Entra/Okta, cloud audit, OAuth logs. Approach: risk detections, peer-baseline comparison, rare-event scoring. Stability: high with complete IdP telemetry. FP risk: Medium.
Examples:
- A user who normally authenticates with MFA suddenly registers a new authentication factor and then performs privileged actions within the same session.
- An employee account that has never approved third-party apps grants OAuth consent to a new application requesting mail read, file access, and offline token permissions.
- A service principal that usually uses short-lived tokens begins generating repeated refresh tokens or long-duration access patterns outside its historical norm.
- A privileged admin account that normally signs in with one managed device starts authenticating with a new device and a newly enrolled MFA method on the same day.
- A user with stable sign-in behaviour suddenly shows unusual token reuse across multiple applications or sessions inconsistent with their normal access pattern.

Rare Process / Service — Execution of a binary or service with low prevalence on that host or host class. Telemetry: EDR, Sysmon Event ID 1, Linux auditd, software inventory. Approach: prevalence scoring, allowlist comparison, digital signature analysis. Stability: high on stable server roles; lower on developer

workstations. FP risk: Low–Medium.

Examples:

- A domain controller suddenly executes `7z.exe`, a binary never before seen on that host class, shortly before large archive creation.
- A Linux web server launches `socat` for the first time, despite no prior history of that tool in its software baseline.
- A workstation starts a newly dropped unsigned binary from `%AppData%`, and that file has zero prevalence across the enterprise.
- A Windows server that normally runs only approved business services suddenly installs and starts a new service with a random-looking name and no trusted signature.
- A production database host executes `rclone`, a utility not previously observed on similar servers, followed by outbound network activity.

Parent-Child Execution — A parent process spawning children it rarely or never should. Telemetry: EDR, Sysmon Event ID 1, auditd. Approach: process lineage rules + rarity modelling by parent. Stability: high on tightly managed servers. FP risk: Low–Medium.

Examples:

- `winword.exe` spawns `powershell.exe`, even though Office applications on that workstation normally never launch script interpreters.
- `w3wp.exe` (IIS worker process) starts `cmd.exe`, an uncommon parent-child relationship that can indicate web shell activity.
- `excel.exe` launches `rundll32.exe` and then a network connection follows, which is not part of normal spreadsheet usage.
- `sshd` on a Linux server spawns `curl` or `wget`, even though interactive SSH sessions on that host class rarely download external content.
- A business application service suddenly spawns `7z.exe` or `rar.exe`, an unusual child process for that parent and host role.

Data Movement — Unusual read/write/copy/export/sync behaviour vs. entity or data-class baseline. Telemetry: DLP, file access logs, object storage audit, SaaS export logs. Approach: volume + destination + object-type + peer baseline. Stability: high when export paths are fully instrumented. FP risk: Medium.

Examples:

- A user who usually views a few HR documents per week suddenly exports entire employee folders to a ZIP archive and syncs them to a personal cloud storage destination.
- A service account that normally reads small sets of objects begins copying thousands of customer records from one S3 bucket to an external account.
- A SaaS user who typically works inside dashboards suddenly performs multiple CSV exports of high-value

reports in one session.
- A workstation that normally accesses Office files locally starts reading large numbers of engineering documents and copying them to a removable device or network share.
- A cloud admin account that usually performs management actions begins bulk snapshot export or cross-region object replication involving sensitive data classes.

Protocol / Application Usage — Non-standard use of ports, protocols, or application features. Telemetry: proxy logs, DNS, NetFlow, SaaS/IdP API logs. Approach: rare-protocol analytics, entropy analysis, user-agent baseline. Stability: medium–high. FP risk: Medium.
Examples:
- A workstation starts making large HTTPS uploads over port 8443 to an external host, even though that port and destination are not part of its normal application profile.
- DNS traffic from a user device suddenly shifts from normal lookup behaviour to long, high-entropy TXT queries consistent with tunneling or covert signalling.
- A browser session begins using an unusual user-agent string and repeatedly calls rarely used SaaS API endpoints that the user never accessed before.
- An internal host starts communicating over SSH on a non-standard port to multiple external systems, outside its normal administrative pattern.
- A cloud application account that usually performs routine API reads begins using bulk export, synchronisation, or token-management features rarely seen in that application context.

Negative Anomaly (Absence) — Expected telemetry stops appearing — logs cleared, agent silenced, process absent. Telemetry: SIEM heartbeat monitoring, log volume baselines, EDR health. Approach: volume baseline on log source; absence detection. Stability: medium — requires baseline of expected "presence". FP risk: Medium.
Examples:
- An EDR agent on a critical server that normally checks in every few minutes stops reporting immediately before suspicious outbound activity begins.
- A domain controller that consistently produces Windows security events suddenly goes silent, with no expected authentication logs during business hours.
- A Linux host that normally sends steady `auditd` records stops emitting process and file-access telemetry after a privileged session starts.
- A firewall or proxy log source with a stable event stream abruptly drops to near zero, even though the protected segment remains active.
- A backup service process that is normally always present on a server is no longer running, followed by unexpected file encryption or deletion activity.

State-Change — Rarely occurring control-plane changes that materially alter trust or exposure. Telemetry: cloud audit, AD audit, IdP audit, SaaS admin logs. Approach: alert on first-occurrence or infrequent-occurrence for a scoped object class. Stability: high for tightly scoped privileged objects. FP risk: Low when scope is narrow.

Examples:

- A new trust policy is added to an IAM role, allowing a previously unrelated principal to assume it for the first time.
- An Active Directory group policy or group membership change creates a new path to privileged access for a sensitive server tier.
- A SaaS administrator changes a tenant setting to allow external sharing on a repository that was previously restricted to internal users.
- An IdP admin modifies conditional access or MFA policy for a privileged group, reducing authentication requirements for high-risk accounts.
- A cloud storage bucket that was private is suddenly changed to public or cross-account accessible, materially increasing exposure.

Multi-Event Correlation — Several individually weak signals combining into an anomalous chain against one entity. Telemetry: SIEM / XDR across all sources. Approach: correlation rules, graph/session stitching, entity risk scoring. Stability: high when carefully tuned. FP risk: Low–Medium.

Examples:

- An account shows an unusual sign-in from an unfamiliar ASN, immediately creates a new OAuth application, then performs bulk file access — no individual signal triggers an alert, but the chain maps to a credential-abuse + persistence + collection pattern.
- A user authenticates normally, a risky process runs on the endpoint, then data is exported to an external destination — three low-confidence signals that in combination describe a post-exploitation sequence.
- A privileged service account registers a new API key, accesses a cloud resource tier it has never touched, and then initiates a large data transfer — each step within normal bounds but the sequence is anomalous.
- An endpoint shows a new unsigned binary, a new outbound network connection, and a credential-access attempt against LSASS in a 10-minute window — individually each might be noise; combined they constitute a high-priority alert.
- A user resets MFA, signs in from a new location, grants OAuth consent to a new app, and creates an inbox forwarding rule to an external domain — the full chain is a documented identity-attack pattern.

---

3. Mapping Anomalies to the ATT&CK Lifecycle

Anomaly detection is most useful when an attacker must create measurable change in an environment. It is least useful when the attacker operates within accepted identity, protocol, and administrative boundaries.

- **Resource Development** (Utility: None, defender-side) — Anomaly types: none observable. Infrastructure acquisition, domain registration, VPS provisioning, and credential staging occur entirely outside defender-controlled environments. No defender-observable signal is generated at the time the activity occurs. The only indirect opportunity is out-of-band threat intelligence: domain monitoring for typosquatting registrations, or certificate transparency log alerts for lookalike certificates. These are TI enrichment sources, not anomaly detection. Limitation: the entire tactic is pre-intrusion and outside the defender's telemetry boundary. [Inferred]
- **Reconnaissance** (Utility: Poor — perimeter telemetry only) — Anomaly types: rate (active scanning), geographic/ASN (unfamiliar source), rare URI (web/directory fuzzing). Passive reconnaissance (OSINT, LinkedIn, Shodan, certificate transparency) produces no defender-observable signal. Active scanning (T1595) produces signals only in perimeter and external-facing infrastructure: aggressive Nmap generates rate anomalies in firewall deny logs; Burp / ffuf / Dirbuster produce high HTTP 404 rates with anomalous or absent User-Agent strings in web server and WAF logs. Detection requires perimeter log collection and alerting tuned specifically for external-facing infrastructure — not the internal/identity focus of most SIEM deployments. Most useful as a *context enrichment signal*: external scanning followed days later by an authentication anomaly from a different IP raises combined confidence materially. Standalone, the alert has low actionability. Limitation: commodity scanners (Shodan, Censys, Masscan) produce identical patterns continuously — distinguishing targeted pre-attack scanning from background internet noise is not reliably possible without threat intelligence enrichment; attackers can trivially slow-scan or rotate IPs to stay below per-source thresholds. [Inferred]
- **Initial Access** (Utility: Poor–Moderate) — Anomaly types: geographic, ASN, rate. Evidence: Midnight Blizzard residential-proxy spray [4]. Limitation: valid credentials, residential proxies, distributed timing.
- **Execution** (Utility: Moderate) — Anomaly types: parent-child, rare process, sequence. Evidence: HAFNIUM `w3wp.exe` → `cmd.exe` [5]; Conti ADFind execution [13]. Limitation: LOTL tools, fileless execution, in-process abuse.
- **Persistence** (Utility: Moderate) — Anomaly types: state-change, identity/access, rare event. Evidence: Storm-1283 OAuth app + VM creation [6]; UNC3944 MFA reset [8]. Limitation: noisy from legitimate admin; requires enrichment.
- **Privilege Escalation** (Utility: Moderate) — Anomaly types: rare process, sequence, identity. Evidence: Kerberoasting RC4 TGS in modern environments [14]. Limitation: legitimate RC4 compatibility

needs; privilege changes are common.

- **Defense Evasion** (Utility: Weak) — Anomaly types: negative anomaly (absence), rare event. Evidence: Conti disabling Defender; `wevtutil cl` log clearing. Limitation: evasion is specifically designed to reduce anomaly surface.
- **Credential Access** (Utility: Moderate–High, concentrated) — Anomaly types: frequency/rate, rare process, sequence. Evidence: password spray Event 4625 clustering; Kerberoasting; DCSync via Impacket [20]. Limitation: distributed spray defeats per-tenant thresholds.
- **Discovery** (Utility: Moderate) — Anomaly types: rare process, peer-group, sequence. Evidence: ADFind/BloodHound execution [13]; LDAP query volume spikes. Limitation: heavy overlap with legitimate admin tooling.
- **Lateral Movement** (Utility: Moderate) — Anomaly types: graph/relationship, peer-group, sequence. Evidence: Conti PsExec + ADMIN$ [13]; NTLM network logon anomalies [16]. Limitation: legitimate admin RDP/SMB traffic.
- **Command and Control** (Utility: Moderate–High) — Anomaly types: temporal, protocol, DNS entropy, volumetric. Evidence: SUNBURST DGA DNS [3]; APT34 DNSpionage TXT records [17]. Limitation: jitter, dormancy, protocol masquerading.
- **Collection / Exfiltration** (Utility: High) — Anomaly types: volumetric, data movement, state-change. Evidence: APT41 SQLULDR2 + PINEGROVE exfiltration [9]; Rclone campaigns [13]. Limitation: SaaS-native exfil generates no signals in perimeter telemetry.
- **Impact** (Utility: High) — Anomaly types: volumetric, rare process, sequence. Evidence: VSS deletion; mass file encryption pattern. Limitation: often detected only after damage has commenced.

---

4. Evidence Register: Real APT Campaigns and Documented Anomaly Patterns

Evidence labels:
- **[Documented]** — the cited source explicitly states the behaviour or detection opportunity.
- **[Inferred]** — the source documents the tradecraft; the detection derivation is the author's reasoned conclusion from those facts.

4.1 SUNBURST / UNC2452 (2020)

Primary source: Mandiant — "SUNBURST Additional Technical Details," December 2020 [3]; Microsoft — "Deep Dive into the Solorigate Second-Stage Activation," January 2021.

Attack summary: Actors attributed to APT29/UNC2452 compromised the SolarWinds Orion software build pipeline, inserting the SUNBURST backdoor into signed Orion update packages. Approximately 18,000 organisations received the trojanised update; approximately 100 were subjected to follow-on operations. Post-exploitation used TEARDROP (memory-only DLL dropper) to load Cobalt Strike.

DNS C2 anomaly patterns:

SUNBURST used a domain generation algorithm (DGA) to encode victim-specific data in subdomain labels of `avsvmcloud[.]com`. The subdomain string was Base32-encoded using a custom alphabet, containing the victim's internal Active Directory domain name and a victim-specific identifier derived from local host data. Mandiant explicitly documented this encoding in the technical details report. [Documented]

Resulting anomaly signals:
- **Subdomain Shannon entropy** on the encoded label was moderate — typically in the 3.7–4.3 range across public samples — higher than human-readable service hostnames but not extreme. Mandiant and independent researchers noted that SUNBURST's encoding was specifically designed to avoid the high-entropy patterns typical of conventional DNS tunneling, limiting the value of pure entropy analytics against this implant. Entropy alone is insufficient to surface this implant; subdomain label length (> 30 characters) and domain-rarity signals are higher-value discriminators. [Inferred — derived from public sample analysis; consistent with Mandiant design observations]
- **Subdomain label length** exceeded 30 characters in encoded queries — far longer than typical service hostnames. [Inferred]
- **Dormancy then periodic callback**: after a 12–14 day dormancy window (no DNS activity, only local environment checks), queries appeared with variable but machine-generated timing. Mandiant documented the dormancy period explicitly. [Documented]
- **No prior resolution history**: `avsvmcloud[.]com` and its subdomains had no prior resolution history in enterprise DNS caches — a domain-rarity signal. [Inferred]

Log sources: Windows DNS debug log (requires explicit enablement); Zeek `dns.log` (`query` field for QNAME, `qtype_name`, `TTL`); proxy logs showing Orion process generating HTTP to non-SolarWinds destinations.

TEARDROP / Cobalt Strike endpoint anomaly:

TEARDROP was a memory-only DLL dropper disguised as a JPEG file (`gracious_truth.jpg`), using a custom XOR obfuscation scheme, loading Cobalt Strike Beacon entirely in memory with no executable

written to disk. Each Cobalt Strike instance was made unique per-machine (distinct folder names, export functions, C2 domains, HTTP request formats). [Documented — Microsoft MSTIC]

Residual detection surface: Sysmon Event 7 (ImageLoad) showing an unsigned or anomalous PE image loaded into the Orion service process [Inferred]; Sysmon Event 8 (CreateRemoteThread) for cross-process injection during lateral movement [Inferred]; Orion service process generating HTTP to non-SolarWinds infrastructure — a destination-rarity anomaly relative to the Orion update-check baseline [Inferred].

Key limitation: The dormancy period was designed to defeat anomaly detection that requires sustained deviation. The actors used Orion's own communication patterns as cover. These factors significantly reduced the actionable anomaly surface.

4.2 HAFNIUM / Exchange ProxyLogon (2021)

Primary source: Microsoft MSTIC — "HAFNIUM Targeting Exchange Servers with 0-Day Exploits," March 2021 [5]; Mandiant — "Responding to Microsoft Exchange Server Zero-Day Vulnerabilities," March 2021 [7]; NSA and Australian Signals Directorate — "Detect and Prevent Web Shell Malware," April 2020 [25].

Attack summary: HAFNIUM (attributed to a Chinese state-sponsored actor) exploited four Exchange Server zero-days (CVE-2021-26855, -26857, -26858, -27065) to achieve pre-authentication server-side request forgery and remote code execution, then deployed webshells.

Exploitation anomaly (IIS / web server logs):

CVE-2021-26855 exploitation generated anomalous HTTP requests from Exchange frontend to backend using cookie-based authentication bypass. IIS logs showed unusual POST requests to `/ecp/` and `/owa/` endpoints from source IPs with no prior access history in that tenant's logs. [Inferred from documented exploitation mechanics]

The NSA/ASD web-shell guidance explicitly recommends alerting on URIs that are accessed by fewer than five unique source IPs in a 30-day window and that return HTTP 200 to POST requests — a "rare URI" pattern applicable here. [Documented — NSA/ASD [25]]

Webshell installation anomaly (endpoint):

Microsoft explicitly documented that `UMWorkerProcess.exe` and `w3wp.exe` wrote ASPX files to the Exchange web root. Post-installation, `w3wp.exe` was observed spawning `cmd.exe` — a parent-child relationship documented by Microsoft and Mandiant as a post-exploitation indicator. [Documented]

This parent-child chain (`w3wp.exe` → `cmd.exe`) has low legitimate prevalence on well-managed Exchange or IIS servers. It is not universal — in development environments or servers running custom web applications with shell-invoking logic, the same chain may occur legitimately. Scope the detection to production internet-facing servers.

Log sources:
- IIS logs: `cs-uri-stem` , `c-ip` , `sc-status` , `cs-bytes` for rare-URI analytics
- Sysmon Event 11 (FileCreate): `TargetFilename` matching `*.aspx` where `Image` is `w3wp.exe` or `UMWorkerProcess.exe`
- Sysmon Event 1 / Windows Security Event 4688 (with command-line logging): `ParentImage = w3wp.exe` , `NewProcessName = cmd.exe`
- MDE DeviceProcessEvents: `InitiatingProcessFileName` in `w3wp.exe, UMWorkerProcess.exe`

Key limitation documented by Microsoft: Actors also deployed malicious native IIS modules (DLLs loaded into `w3wp.exe` address space). These execute in-process and generate no child-process events. Detection then depends on Sysmon Event 7 (ImageLoad) for unsigned or anomalous DLLs loaded into IIS worker processes. [Documented — Microsoft MSTIC]

4.3 Conti Ransomware (2021–2022)

Primary source: The DFIR Report — "BazarCall to Conti Ransomware via Trickbot and Cobalt Strike," August 2021; "BazarLoader to Conti Ransomware in 32 Hours," September 2021; "CONTInuing the Bazar Ransomware Story," November 2021 [13].

Attack summary: Conti affiliates used BazarLoader/BazarCall (phone-based phishing followed by document delivery) or IcedID as initial access. A Cobalt Strike Beacon beachhead was established, followed by internal reconnaissance using freely available tools, lateral movement via SMB and PsExec, and domain-wide ransomware deployment.

Reconnaissance anomalies — explicitly documented by DFIR Report:

- `adfind.exe` executed from the Cobalt Strike beacon process; output written to `C:\Windows\Temp\adf\` as: `ad_users.txt` , `ad_computers.txt` , `ad_group.txt` , `trustdmp.txt` , `subnets.txt` , `ad_ous.txt` [Documented]
- BloodHound executed in-memory via Cobalt Strike injection (no on-disk binary drop) [Documented]
- `nltest /domain_trusts /all_trusts` , `net group "Domain Admins" /domain` , `whoami /all` run from the beacon process [Documented]

Detection signals:
- `adfind.exe` has near-zero baseline prevalence in most enterprise environments; any EDR rare-process alert would fire immediately. [Inferred — prevalence depends on environment]
- ADFind output files in `C:\Windows\Temp\adf\` — Sysmon Event 11 (FileCreate) with non-system filenames in system temp paths by a non-system process. [Inferred]
- BloodHound in-memory generates high-volume LDAP queries to domain controllers from an endpoint host; Windows Server 2016 and later can log expensive LDAP queries via Event 1644 (requires explicit enablement). [Inferred]
- Discovery commands run as child processes of an injected process (e.g., `explorer.exe` → `adfind.exe`) — a sequence anomaly. [Inferred]

Lateral movement anomalies — documented by DFIR Report:

- SMB lateral movement; Conti DLL dropped to `ADMIN$` shares and executed remotely via PsExec [Documented]
- RDP proxied through the IcedID process on port 8080 [Documented]
- Internal SMB port 445 scanning for target identification [Documented]

Detection signals:
- Windows Security Event 5140 (network share accessed): `ShareName = \\*\ADMIN$` from a workstation context — anomalous in most environments. [Inferred]
- Windows Security Event 7045 (System log) or 4697 (Security log): new service installed, specifically `psexesvc` or randomly named services characteristic of PsExec. [Inferred]
- Event 4624 (Logon Type 3) showing new host-to-host authentication pairs with no prior communication history — graph anomaly requiring a 60–90-day NetFlow/auth baseline to surface. [Inferred]
- NetFlow: port 445 connection attempts from a single internal host to many internal hosts in a short window — rate anomaly on east-west traffic. [Inferred]

Pre-encryption anomalies — documented by DFIR Report:

- Windows Defender disabled via PowerShell `Set-MpPreference -DisableRealtimeMonitoring $true` [Documented]
- VSS shadow copies deleted via `vssadmin.exe delete shadows /all /quiet` [Documented]
- Domain-wide Conti deployment via PsExec batch files within under 30 minutes [Documented]

Detection signals:
- Sysmon Event 13 (Registry value set) on Defender configuration keys; absence of subsequent Defender events from a host is a negative anomaly detectable via SIEM heartbeat or log-source volume monitoring.

[Inferred]
- Windows Security Event 4688 with command-line logging, or Sysmon Event 1: `vssadmin.exe` with `delete shadows` arguments. On workstations this is effectively never legitimate. [Inferred — the DFIR Report documents the attacker action; the detection recommendation is the author's derived response]
- Windows Security Event 1102 fires whenever the Security audit log is cleared. The detection response — treat any 1102 outside a change-management window as high priority — is a standard recommendation. [Inferred — Event 1102 is documented; the "alert immediately" response is operational guidance, not a statement from the cited source]

4.4 APT34 / OilRig DNS Tunneling (2018–2024)

Primary sources: Palo Alto Unit 42 — "Behind the Scenes with OilRig" [17]; Cisco Talos — "DNSpionage Campaign Targets Middle East," November 2018; Check Point Research — "Iran's APT34 Returns with an Updated Arsenal," 2021.

Attack summary: APT34 (attributed to Iranian state-sponsored actors) consistently used DNS tunneling as a C2 channel across multiple toolsets including BONDUPDATER, RDAT, and the DNSpionage implant. Data exfiltration and command delivery were encoded in DNS query subdomain strings or TXT record responses.

Documented DNS tunneling technique:

Cisco Talos and Palo Alto Unit 42 explicitly documented that APT34 implants queried custom subdomain strings encoding exfiltrated data, and used DNS TXT record responses to receive commands from attacker-controlled authoritative DNS servers. [Documented]

Observable anomaly signals:

- **Subdomain label length > 30 characters** — Log source: DNS debug log; Zeek `dns.log`. Human-readable labels are rarely this long.
- **Subdomain Shannon entropy > 4.0** (on subdomain portion) — Log source: DNS debug log; Zeek `dns.log`. Illustrative starting point; CDN subdomains and some legitimate services also exceed this — environment calibration required.
- **TXT record query volume** (high frequency for a single domain) — Log source: DNS resolver logs. TXT queries are rare in most enterprise DNS; high volume is anomalous.
- **DNS query cadence** (coefficient of variation CV < 0.20 over 6+ queries to same domain) — Log source: DNS logs + NetFlow. Low CV indicates machine-generated regularity — an illustrative threshold, not a universal rule.

- **TXT : A query ratio > 1.0** to same domain — Log source: DNS resolver logs. Abnormal for any legitimate service.

Key limitation: DNS tunneling is undetectable without full QNAME capture in DNS resolver logs. Many organisations either do not log DNS queries at all, or forward only partial data. Without the full subdomain string, entropy analysis is not possible.

4.5 MOVEit / Cl0p Campaign (2023)

Primary source: CISA Advisory AA23-158A — "CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability," June 2023 [19]; Mandiant; Rapid7; Akamai.

Attack summary: The Cl0p group exploited a SQL injection vulnerability (CVE-2023-34362) in MOVEit Transfer's web application to deploy the LEMURLOOT webshell and exfiltrate data from hundreds of organisations within a 48-hour window in May 2023.

LEMURLOOT webshell — documented evasion and detection signals:

CISA advisory AA23-158A documented the following explicitly: [Documented]
- Webshell deployed as `human2.aspx` or `_human2.aspx` in the MOVEit Transfer web root, mimicking the legitimate `human.aspx`
- Returns HTTP 404 to any request not containing the custom header `X-siLock-Comment` with the correct GUID-format password value — active evasion of passive scanners
- Control flow headers: `X-siLock-Step1`, `X-siLock-Step2`, `X-siLock-Step3`
- Created a local Windows user account named `"Health Check Service"` [Documented]
- Enumerated files and retrieved the MOVEit configuration file containing database credentials [Documented]

- **SQL injection** (Protocol anomaly) — Anomalous POST body to MOVEit endpoints. Log source: IIS logs (`cs-uri-stem`, POST body if captured).
- **Webshell write** (Parent-child / file creation) — `w3wp.exe` writing ASPX to MOVEit web root. Log source: Sysmon Event 11; Windows Security 4663 (object access with SACL).
- **Webshell access** (Rare URI) — POST to `human2.aspx` returning HTTP 200. Log source: IIS access logs.
- **Account creation** (State-change) — Event 4720: new account `"Health Check Service"` created. Log source: Windows Security Event 4720.

- **Data exfiltration** (Volumetric) — Large outbound transfer from MOVEit server. Log source: NetFlow; firewall egress logs.

Event 4720 (`"Health Check Service"` created by a web application process) is a state-change detection requiring no baseline — any account created under these circumstances warrants investigation. The combination of webshell + account creation is documented as a detection opportunity in CISA AA23-158A. [Documented]

4.6 Midnight Blizzard / Cozy Bear (2023–2024)

Primary source: Microsoft MSTIC — "Midnight Blizzard: Guidance for Responders on Nation-State Attack," January 2024 [4].

Attack summary: Midnight Blizzard (APT29/Cozy Bear) conducted a sustained password spray campaign against Microsoft's corporate environment using residential proxy infrastructure. A legacy test account without MFA was compromised. Email from executive and security team mailboxes was exfiltrated. Microsoft's blog states attack volume increased tenfold between January and February 2024. [Documented]

Password spray evasion:

Microsoft explicitly documented that Midnight Blizzard used low-volume attempts from residential proxy infrastructure to distribute authentication failures across thousands of IP addresses. [Documented] The interpretation that this strategy was designed specifically to remain below standard alert thresholds is the author's inference from the documented distribution pattern. [Inferred]

Detection implications:
- Microsoft Entra Identity Protection's "Password spray" named detection type fires based on cross-tenant telemetry — provider-level view that tenant-local monitoring cannot replicate. [Documented — Microsoft Entra ID Protection documentation]
- Tenant-local per-IP rate limiting was insufficient; the spray pattern was only detectable at provider level. [Documented]
- The compromised legacy test account had sparse sign-in history, producing a weak entity baseline. [Inferred from documented account characteristics]

Post-compromise OAuth abuse:

After initial access, Microsoft documented the creation of malicious OAuth applications used to access Exchange Web Services (EWS) for email collection. [Documented]

Detection signals:
- Entra audit log: new application registration with `Mail.Read` or `Mail.ReadAll` scope, especially where the consenting account had unfamiliar sign-in properties within the preceding 24 hours. [Inferred]
- EWS access by an application not previously seen accessing EWS in that tenant — application-level protocol anomaly. [Inferred]

4.7 Scattered Spider / UNC3944 (2023)

Primary source: Mandiant — "UNC3944 Targets SaaS Applications," Google Cloud Security Blog, 2023 [8]; CISA Advisory AA23-320A.

Attack summary: UNC3944/Scattered Spider used help-desk vishing to obtain MFA resets for high-privilege accounts, then exploited cloud and SaaS environments for persistence and data exfiltration, including MGM Resorts International and Caesars Entertainment.

Help-desk vishing and MFA reset — documented:

Mandiant documented that actors called IT help desks posing as employees, using pre-obtained PII to bypass identity verification and request MFA factor resets. [Documented]

Detection signals in IdP logs:
- Okta System Log event `user.mfa.factor.update` or `user.mfa.factor.deactivate` for a privileged account, followed within 30–60 minutes by a sign-in from an IP with no prior history for that account. [Inferred — CISA advisory notes these as detection opportunities]
- Microsoft Entra audit log: `Add registered security info` or `Delete registered security info` operations for accounts with privileged role assignments. [Inferred]
- High volume of MFA denial events (`user.mfa.attempt.not.completed` in Okta) against a single account in a short window — MFA fatigue pattern; rate anomaly on MFA push denials per account per hour. [Documented — CISA AA23-320A describes MFA fatigue as documented technique]

SaaS data exfiltration — documented:

Mandiant documented that UNC3944 used Airbyte, Fivetran, Rclone, and WinSCP to exfiltrate data. Airbyte and Fivetran are legitimate data integration tools; their use for exfiltration generates no signals in perimeter firewall egress or EDR process telemetry when the sync connector executes within the SaaS provider's infrastructure. Detection depends on the SaaS platform's own audit log recording the connector creation and data movement. [Documented]

Mandiant's reporting states explicitly that without SaaS audit log collection, defenders may not discover the intrusion until an extortion demand arrives. [Documented]

4.8 Storm-0558 and OAuth Abuse Campaigns (2023)

Primary source: Microsoft MSTIC — "Analysis of Storm-0558 Techniques for Unauthorized Email Access," August 2023; Microsoft MSTIC — Storm-1283 OAuth cryptomining reporting, 2023 [6].

Storm-0558 — forged tokens:

Microsoft documented that Storm-0558 used a forged MSA (Microsoft account) consumer signing key to forge authentication tokens, using them to access Exchange Online and OWA mailboxes. The initial detection came from a customer reporting anomalous mailbox access; it was not identified by automated detection tooling before that report. [Documented]

Microsoft's post-incident analysis identified that `MailItemsAccessed` records in the Microsoft 365 Unified Audit Log (requires Purview Audit Premium — E5 or add-on licensing) provided the evidence needed to scope the incident. [Documented]

The "Token issuer anomaly" detection type in Microsoft Entra Identity Protection appears inapplicable to Storm-0558 based on Microsoft's public documentation of the detection category, though Microsoft has not publicly confirmed this. Microsoft documents Token issuer anomaly as targeting a potentially compromised **SAML token issuer** — a federated identity provider deviation. Storm-0558 did not involve a SAML issuer: the attack used a forged **MSA consumer signing key** to mint authentication tokens outside the enterprise identity plane entirely. Based on those published definitions, the detection category appears to address a different threat model. Whether any Entra Identity Protection detection type would have fired for Storm-0558 is not stated in Microsoft's published post-incident reporting. [Inferred — derived from comparing Microsoft's published Token issuer anomaly definition against the documented Storm-0558 attack mechanism; Microsoft has not published a definitive statement on this specific mapping]

Storm-1283 — OAuth app + cloud compute:

Microsoft documented that a compromised user created a new OAuth application, which then deployed Azure Virtual Machines for cryptomining. [Documented]

Detection: Cloud audit log (`Microsoft.Compute/virtualMachines/write`) recording VM creation by an OAuth application or service principal — a state-change anomaly. Alert on VM creation where the initiating principal is an OAuth application or a user account with unfamiliar sign-in properties. [Inferred — detection approach derived from documented tradecraft]

4.9 Volt Typhoon (2023–2024)

Primary source: CISA/NSA/FBI and partner agencies — Advisory AA24-038A, "People's Republic of China State-Sponsored Cyber Actor Living off the Land to Evade Detection," February 2024 [10]; Microsoft MSTIC Volt Typhoon reporting, May 2023 [4].

Attack summary: Volt Typhoon (attributed to Chinese state-sponsored actors) maintained persistent, stealthy access to US critical infrastructure networks. Their defining characteristic is systematic use of living-off-the-land (LOTL) binaries, valid administrative credentials, and SOHO (Small Office/Home Office) proxy infrastructure to suppress anomaly visibility.

CISA's advisory explicitly warns that many of the behavioural findings associated with Volt Typhoon can also occur in legitimate administrative operations and should not be treated as malicious without corroboration from multiple data sources. [Documented]

Documented TTPs and detection opportunities:

- **Credential extraction** — Command: `ntdsutil "ac i ntds" ifm "create full C:\Temp\ntds" q q`. Signal: `ntdsutil` with IFM arguments on a non-DC host — contextual anomaly. Log source: Event 4688 (with command-line); Sysmon Event 1. CISA limitation: legitimate DC backup operations use identical commands.
- **Network tunneling** — Command: `netsh portproxy add v4tov4 listenport=X connectport=Z connectaddress=W`. Signal: `netsh portproxy` configuration on workstation — contextual anomaly. Log source: Event 4688; Sysmon Event 1. CISA limitation: legitimate VPN or WSL2 configurations may also create portproxy rules.
- **Log clearing** — Commands: `wevtutil cl System` / `wevtutil cl Security`. Signal: Event 1102 (Security log cleared); negative anomaly: gap in expected event stream. Log source: Windows Security Event 1102. CISA limitation: legitimate maintenance may clear logs.
- **Lateral movement** — Action: RDP, WMI with valid credentials. Signal: graph anomaly — new host-to-host pair with no prior auth history. Log source: Event 4624 (Logon Type 3/10); NetFlow. CISA limitation: significant legitimate admin overlap — CISA explicitly warns.
- **SOHO proxy sign-ins** — Action: sign-ins from residential ISP or SOHO router IP ranges. Signal: geographic/ASN anomaly — unfamiliar ISP for the account. Log source: IdP sign-in logs. CISA limitation: consumer ISP churn generates false positives.

Windows Security Event 1102 fires whenever the Security audit log is cleared, regardless of audit policy configuration. NSA recommends treating any 1102 event without a corresponding change management ticket as high priority. [Documented — NSA guidance]

4.10 APT41 / Winnti — MESSAGETAP (2019) and M-Trends 2025 Exfiltration (2024)

Primary sources: Mandiant — "MESSAGETAP: Who Is Reading Your Text Messages?" October 2019; Mandiant M-Trends 2025 [9].

MESSAGETAP (2019):

Mandiant explicitly documented that MESSAGETAP was a 64-bit ELF shared library deployed on Linux-based SMSC (Short Message Service Centre) servers at telecommunications providers. It used `libpcap` to perform raw packet capture, read configuration files every 30 seconds to refresh IMSI/MSISDN target lists, and parsed SMS traffic matching configured criteria for exfiltration. [Documented]

Detection signals:
- A process loading `libpcap.so` on a telecom server where packet capture is not operationally expected — detectable via Linux auditd with `syscall` rules or process inventory tooling. [Inferred]
- Regular (every 30-second) file reads of configuration files from non-standard paths — detectable via Linux auditd `inotify` or `open` syscall auditing if the paths are known. [Inferred]
- MESSAGETAP would not match a known-good software inventory for the SMSC system — rare-process/service detection if an inventory baseline is maintained. [Inferred]

M-Trends 2025 APT41 exfiltration:

Mandiant M-Trends 2025 documented APT41 using SQLULDR2 (a legitimate Oracle export utility) and PINEGROVE (a custom tool) to exfiltrate data to OneDrive. [Documented]

Detection: SQLULDR2 execution is a rare-process anomaly on most systems. Outbound data to OneDrive from a database server is a data-movement anomaly if cloud storage destination baselines are maintained per host class. [Inferred]

4.11 CISA AA22-277A — Impacket Lateral Movement in Defense Industrial Base Compromise (2022)

Primary source: CISA Advisory AA22-277A — "Impacket and Exfiltration Tool Used to Steal Sensitive Information from Defense Industrial Base Organization," October 2022 [20].

Attribution note: CISA Advisory AA22-277A does not name a specific threat actor or group. This section describes the advisory's documented findings; attribution to any named actor is not stated in the primary source and is not claimed here.

Attack summary: CISA advisory AA22-277A documented actors using Impacket's `wmiexec.py` for remote execution and `secretsdump.py` for credential extraction (DCSync) in a defense industrial base network. [Documented]

Detection signals:

`wmiexec.py` remote execution:
- `WmiPrvSE.exe` spawning `cmd.exe` — parent-child chain documented as a remote WMI execution indicator. [Documented — CISA advisory]
- Windows Security Event 4624 (Logon Type 3) from the source host to the target. [Inferred]
- `Microsoft-Windows-WMI-Activity/Operational` Event 5861 (new permanent WMI event subscription) for persistence via WMI. [Inferred]

`secretsdump.py` DCSync:
- DRSUAPI (Directory Replication Service Remote Protocol) traffic from a host that is not a domain controller — observable in NetFlow as TCP/135 (RPC endpoint mapper) traffic from a workstation to domain controllers, followed by high-port RPC calls. [Inferred]
- Windows Security Event 4662 with replication GUIDs from a non-machine-account subject — see Section 6.2. [Documented approach — CISA advisory, Black Lantern Security]

4.12 Lazarus Group / DPRK — 3CX Supply Chain (2023)

Primary sources: CrowdStrike — "CrowdStrike Falcon Detects 3CXDesktopApp Supply Chain Attack," March 2023; Mandiant — "3CX Software Supply Chain Compromise Initiated by a Prior Software Supply Chain Compromise," April 2023.

Attack summary: Lazarus Group compromised the 3CX Desktop App update distribution pipeline, distributing a trojanised, digitally signed installer via 3CX's update infrastructure. 3CX reported a customer base of approximately 600,000 organisations; the number that actually received and executed the malicious build is smaller and has not been precisely disclosed. The payload performed staged download of additional malware after a dormancy period.

CrowdStrike and SentinelOne published behavioural detections within hours of the campaign becoming public, catching the trojanised application based on its runtime behaviour rather than its signature — specifically because EDR IOA/behavioural logic flagged a signed softphone application performing process injection and downloading executable content from GitHub repositories. [Documented — CrowdStrike blog]

Detection signal: A known-trusted application (`3CXDesktopApp.exe`) making HTTP requests to non-3CX GitHub repositories followed by loading in-memory content — a destination-rarity anomaly combined with behavioural IOA. [Documented — CrowdStrike; Inferred for specific log fields]

---

5. Detection by Log Source and Security Device

5.1 Windows Security Event Log

Effective anomaly detection on Windows requires enabling Advanced Audit Policy settings beyond defaults. The table below uses the correct audit policy paths from Microsoft's documentation.

Critical Event IDs and required audit policy subcategories:

Logon / Logoff category (enabled by default):

- **Event 4624** — Successful logon. Subcategory: Logon. Default: enabled (basic). Use: PTH heuristics; lateral movement graph; baseline.
- **Event 4625** — Failed logon. Subcategory: Logon. Default: enabled (basic). Use: password spray rate and spread.
- **Event 4648** — Logon with explicit credentials (RunAs or alternative credentials). Subcategory: Logon. Default: not enabled. Use: lateral movement indicator.
- **Event 4672** — Special privileges assigned to new logon session. Subcategory: Special Logon. Default: enabled. Use: privilege escalation — new session with SeDebugPrivilege, SeTcbPrivilege.

Detailed Tracking / DS Access (require explicit audit policy configuration):

- **Event 4688** — Process created. Subcategory: Process Creation. Default: enabled (basic); command-line capture requires explicit GPO. Use: LOTL detection; credential tool execution; post-exploitation.
- **Event 4662** — Operation performed on AD directory object. Subcategory: Directory Service Access. Default: not enabled; requires SACL on domain NC root. Use: DCSync detection via replication GUIDs.

Account Management (enabled by default):

- **Event 4720** — User account created. Subcategory: User Account Management. Use: new account creation (LEMURLOOT; attacker backdoor accounts).
- **Events 4728 / 4732 / 4756** — Member added to security/local/universal group. Subcategory: Security Group Management. Use: persistence via privileged group membership.

Account Logon — enabled on DCs:

- **Event 4769** — Kerberos service ticket (TGS) requested. Subcategory: Kerberos Service Ticket Operations. Use: Kerberoasting heuristic (RC4 encryption type).
- **Event 4776** — NTLM credential validation at DC. Subcategory: Credential Validation. Use: NTLM spray baseline; NTLM usage anomaly.

Object Access / System (require explicit configuration):

- **Event 4697** — Service installed in the system. Subcategory: Security System Extension. Default: not enabled. Use: malicious service installation.
- **Event 4698** — Scheduled task created. Subcategory: Other Object Access Events. Default: not enabled. Use: persistence via scheduled tasks.
- **Event 5140** — Network share accessed. Subcategory: File Share. Default: not enabled. Use: ADMIN$ access from non-admin workstations.
- **Event 7045** (System log) — New service installed. Default: always on. Use: PsExec service deployment; malicious service.
- **Event 1102** — Security audit log cleared. Subcategory: Other Events. Default: always generated when Security log is cleared. Use: log clearing for defense evasion — high-priority.

Non-default audit settings required:
- Event 4688 with full command-line: requires Group Policy → `Computer Configuration → Windows Settings → Security Settings → Advanced Audit Policy → Detailed Tracking → Process Creation` (Success) **and** Group Policy → `Computer Configuration → Administrative Templates → System → Audit Process Creation → Include command line in process creation events`
- Event 4662 (DCSync): requires both "Directory Service Access" audit policy (DS Access → Directory Service Access, Success) **and** explicit SACL on the domain NC root object — a non-trivial configuration step
- Events 4697, 4698, 5140: not enabled by default; require explicit audit policy changes
- WMI activity: `Microsoft-Windows-WMI-Activity/Operational` log — Events 5857, 5858, 5860, 5861 — available by default once the Operational channel is enabled. Additional WMI trace/debug logging

requires separately enabling analytic and debug logs via Event Viewer; these are distinct from the Operational channel.

5.2 Sysmon

Sysmon (System Monitor, part of Sysinternals) provides endpoint telemetry beyond the native Windows Security log. It requires explicit deployment and a configuration file.

High-value Sysmon Event IDs:

- **Event 1 — Process Create** — Key fields: `Image`, `CommandLine`, `ParentImage`, `ParentCommandLine`, `User`, `Hashes`, `IntegrityLevel`. Use: parent-child anomalies; rare process; LOTL command-line.
- **Event 3 — Network Connection** — Key fields: `Image`, `DestinationIp`, `DestinationPort`, `Protocol`, `Initiated`. Use: process-network pairing — process making unusual outbound connection.
- **Event 6 — Driver Load** — Key fields: `ImageLoaded`, `Hashes`, `Signed`, `SignatureStatus`. Use: BYOVD (Bring Your Own Vulnerable Driver); unsigned driver load.
- **Event 7 — Image Load** — Key fields: `Image`, `ImageLoaded`, `Signed`, `SignatureStatus`. Use: unsigned DLL loaded into signed process; in-memory loader detection.
- **Event 8 — CreateRemoteThread** — Key fields: `SourceImage`, `TargetImage`, `StartAddress`, `StartModule`. Use: cross-process thread injection — `StartModule = "Unknown"` indicates shellcode.
- **Event 10 — ProcessAccess** — Key fields: `SourceImage`, `TargetImage`, `GrantedAccess`, `CallTrace`. Use: LSASS access for credential dumping (see Section 6.4).
- **Event 11 — FileCreate** — Key fields: `Image`, `TargetFilename`. Use: webshell writes (ASPX from `w3wp.exe`); dropper writing payload to disk.
- **Events 12 / 13 — Registry Add / Set** — Key fields: `EventType`, `TargetObject`, `Details`. Use: run-key persistence; security-tool configuration modification.
- **Events 17 / 18 — Pipe Created / Connected** — Key fields: `PipeName`, `Image`. Use: named-pipe lateral movement; Cobalt Strike default pipe names (`\MSSE-*-server`, `\postex_*`).
- **Event 22 — DNS Query** — Key fields: `Image`, `QueryName`, `QueryStatus`, `QueryResults`. Use: process-level DNS resolution from a process that should not be resolving external names.
- **Event 25 — ProcessTampering** — Key fields: `Image`, `Type`. Use: process hollowing; herpaderping; transacted file-based evasion.

Operational notes:
- Sysmon Event 10 against `lsass.exe` generates substantial volume in default configurations. Filter to specific `GrantedAccess` masks to make it actionable (see Section 6.4).
- Sysmon Event 8 (CreateRemoteThread) generates noise from legitimate inter-process communication. Filter to `StartModule = "Unknown"` to target shellcode injection from unregistered memory regions.
- Cobalt Strike default named-pipe names (`\MSSE-*-server`, `\status_*`, `\postex_*`) are documented IOC patterns detectable via Sysmon Event 17/18. These patterns detect default, uncustomized Cobalt Strike deployments. Operators running Malleable C2 profiles with customized pipe names will not match. The detection is high-confidence in presence — if the named pipe appears, it is a strong indicator — but absence does not indicate absence of Cobalt Strike. Treat as a high-signal heuristic requiring allowlisting, not a universal signature — consistent with the classification in Section 9.2.
- Recommended baseline configurations: SwiftOnSecurity sysmon-config or Olaf Hartong's modular sysmon-config — both are publicly available and community-maintained.

5.3 EDR Platforms

> ***Vendor capability notice:*** *Product capabilities described in this section are drawn from public vendor documentation and vendor-authored blog posts. Independent benchmarking of specific detection coverage and false-positive rates is limited. Treat every capability listed as a hypothesis for validation in your own environment, not as an established property. Named detection categories are subject to change as vendors revise product lines.*

CrowdStrike Falcon

CrowdStrike's Falcon uses Event Stream Processing (ESP) to correlate over 1,000 sensor event types into stateful behavioural chains. IOAs (Indicators of Attack) are the primary detection unit — behavioural sequences, not individual events. [Documented — CrowdStrike blog [21]]

Documented IOA detection categories:
- **Credential theft**: Non-standard process accessing LSASS memory and attempting credential extraction — documented example: Mimikatz sekurlsa running in a reflectively injected PowerShell module
- **Process injection**: A legitimate process receiving injected code that then performs unusual operations (network connection, credential access)
- **Ransomware behaviour**: Mass file rename/encryption + VSS deletion + security tool disablement
- **Lateral movement**: Credential use + remote process creation + ADMIN$ access chain
- **Office macro / document execution chains**: Office application spawning script interpreters

CrowdStrike's AI-powered IOA expansion (announced 2023) uses ML trained on Falcon telemetry to generate IOA patterns beyond human-authored rules. This is a vendor product claim; independent validation data is not published. [Documented as product claim — CrowdStrike]

Microsoft Defender for Endpoint (MDE)

MDE generates behavioural alerts when process chains match documented patterns. Documented built-in alert categories relevant to anomaly detection include:
- "Suspicious process execution by web server worker process" — fires on `w3wp.exe` or similar spawning shell interpreters
- "Suspicious credential theft activity" — fires on LSASS access patterns consistent with documented dumping tools
- "Suspicious scheduled task creation" — fires on tasks created by uncommon parent processes
- "Possible attempt to access Primary Refresh Token (PRT)" — requires MDE + Entra ID P2 integration

These are Microsoft product documentation claims; detection coverage and false positive rates vary by environment configuration. [Documented as product capability — Microsoft Learn]

5.4 Network Detection and Response

> ***Vendor capability notice:*** *Product capabilities described in this section are drawn from public vendor documentation and vendor-authored blog posts. Independent benchmarking of specific detection coverage and false-positive rates is limited. Treat every capability listed as a hypothesis for validation in your own environment, not as an established property. Named detection categories are subject to change as vendors revise product lines.*

Zeek / Corelight

Zeek generates structured log files from packet captures. Key log files for anomaly detection:

- **`dns.log`** — Key fields: `query`, `qtype_name`, `rcode_name`, `answers`, `TTL`. Use: DNS tunneling (entropy, query length, TXT query ratio); DGA; C2 domain rarity.
- **`conn.log`** — Key fields: `id.orig_h`, `id.resp_h`, `id.resp_p`, `proto`, `duration`, `orig_bytes`, `resp_bytes`. Use: beaconing (connection interval analysis); volumetric exfiltration; port scan.
- **`http.log`** — Key fields: `host`, `uri`, `user_agent`, `method`, `status_code`, `request_body_len`. Use: rare URI; anomalous User-Agent; C2 over HTTP.

- **`ssl.log`** — Key fields: `server_name`, `issuer`, `subject`, `validation_status`, `ja3`, `ja3s`. Use: JA3/JA3S fingerprinting for C2 tooling; invalid certificate chains.
- **`files.log`** — Key fields: `mime_type`, `filename`, `md5`, `sha256`, `source`, `tx_hosts`, `rx_hosts`. Use: unexpected file transfer types; malware download.
- **`kerberos.log`** — Key fields: `request_type`, `client`, `service`, `error_msg`, `cipher`. Use: Kerberoasting (`cipher = RC4` in modern environment); pass-the-ticket.
- **`smb_files.log`** — Key fields: `action`, `path`, `name`, `size`. Use: ADMIN$ write; ransomware file modification pattern.

RITA (Real Intelligence Threat Analytics) — open-source framework built on Zeek output, with documented detection modules for beaconing (skew/MADM algorithm on connection intervals), DNS tunneling (subdomain entropy and unique subdomain count per registered domain), and long connections.

Vectra AI

Vectra AI's Cognito platform applies ML models (the vendor documents 150+ detection models) to network metadata without packet decryption. Documented detection categories include: intermittent beaconing, domain fronting, C2 over encrypted enterprise protocols, lateral movement to hosts outside established communication graph, unusual LDAP query volumes, and data transfer volume anomalies. [Documented — Vectra AI product documentation [22]] These are vendor capability claims; independent benchmark data for specific environments is not published.

5.5 Identity and Access Management Platforms

Microsoft Entra Identity Protection — Risk Detection Types

> *Microsoft revises Entra ID Protection detection names, tiers, and availability frequently. The tables below reflect Microsoft's published documentation as of April 2026. For the current canonical list, consult Microsoft Learn: https://learn.microsoft.com/entra/id-protection/concept-identity-protection-risks*

Microsoft Entra ID Protection provides named risk detections, each representing a documented anomaly model. The following list reflects Microsoft's published documentation as of April 2026; Microsoft may update detection names, availability, or licensing requirements without notice [4].

Sign-in risk detections (requires Entra ID P2 for Premium types):

Non-premium (available without Entra ID P2):

- **Anonymous IP address** (real-time) — Sign-in from Tor exit node or known anonymiser.

Premium — requires Entra ID P2:

- **Unfamiliar sign-in properties** (real-time) — Deviation from historical IP, ASN, location, device, browser, tenant subnet.
- **Atypical travel** (offline) — Two sign-ins from geographically distant locations within an infeasible travel window. Native Entra ID Protection detection; no additional licensing beyond Entra ID P2.
- **Impossible travel** (offline) — Cross-service correlation of sign-in locations via Microsoft Defender for Cloud Apps (MDA). **Distinct from Atypical travel** — requires MDA licensing (Microsoft 365 E5 Security or standalone MDA) in addition to Entra ID P2.
- **Malicious IP address** (offline) — Sign-in from IP associated with confirmed attack activity.
- **Password spray** (real-time or offline) — Spray pattern detected across the tenant via provider-level telemetry.
- **Verified threat actor IP** (real-time) — Sign-in from infrastructure associated with known threat actor groups.
- **Anomalous Token** (real-time or offline) — Token characteristics inconsistent with expected issuer, lifetime, or properties.
- **Token issuer anomaly** (real-time or offline) — Token issued by an unexpected authority.
- **Suspicious inbox manipulation rules** (offline) — Inbox rules forwarding to external domains or deleting specific categories.
- **Suspicious inbox forwarding** (offline) — New external email forwarding configuration.
- **Mass access to sensitive files** (offline) — File access volume above per-user or per-session baseline.
- **New country** (offline) — First-ever sign-in from a particular country for that account.
- **Suspicious browser** (offline) — Browser and OS combination inconsistent with historical profile.
- **Activity from anonymous IP address** (offline) — Distinguishable from basic anonymous IP by additional context signals.

User risk detections:

- **Leaked credentials** — Credential found in breach dumps, paste sites, or dark web forums.
- **Attacker in the Middle (AiTM)** — Reverse-proxy phishing stealing session tokens (requires M365 E5 or Defender for Cloud Apps).

- **Suspicious API traffic** — Anomalous Microsoft Graph API or directory enumeration activity.
- **Possible PRT access** — Attempt to access the Primary Refresh Token (requires MDE integration).
- **Anomalous user activity** — Composite deviation across multiple behavioural dimensions.
- **User reported suspicious activity** — User denied an MFA push notification.

Okta System Log — High-Value Events:

- `user.mfa.factor.update` — MFA factor change — alert for privileged accounts outside change windows.
- `user.mfa.factor.deactivate` — MFA factor removal — high-sensitivity alert.
- `user.session.impersonation.initiate` — Administrator impersonating another user.
- `user.account.privilege.grant` — Privilege assignment.
- `security.threat.detected` — Okta ThreatInsight IP-based threat intelligence correlation.
- `application.user_membership.add` — User added to application — alert for sensitive apps.
- `user.authentication.auth_via_mfa` (outcome: FAILURE) — MFA denial — rate anomaly for MFA fatigue detection.

5.6 Cloud Security Services

AWS GuardDuty

GuardDuty evaluates API calls against per-user baselines tracking who made the request, from what location/IP, and to which API. Key finding type categories by ATT&CK stage [23]:

- **Discovery** — `Discovery:IAMUser/AnomalousBehavior`: unusual IAM discovery calls (`GetRolePolicy`, `ListAccessKeys`, `DescribeInstances`) from atypical source.
- **Credential Access** — `CredentialAccess:IAMUser/AnomalousBehavior`: `GetSecretValue`, `GenerateDbAuthToken` from unusual principal or location.
- **Defense Evasion** — `DefenseEvasion:IAMUser/AnomalousBehavior`: `DeleteFlowLogs`, `StopLogging`, `DisableAlarmActions`.
- **Exfiltration** — `Exfiltration:IAMUser/AnomalousBehavior`: `PutBucketReplication`, `CreateSnapshot`, `RestoreDBInstanceFromDBSnapshot`.

Microsoft Sentinel — Anomaly Analytics

Sentinel provides ML-based anomaly analytics rules that learn per-entity baselines and score deviations. These rules appear in the `Anomalies` table alongside other log data. Key properties [24]:

- Anomaly rules require a learning period (typically 14–28 days) before producing output
- Results are scored deviations, not binary alerts — intended for correlation, not direct incident creation
- Anomaly rules cannot be edited directly; the workflow is to duplicate the template and modify the copy
- Microsoft updates anomaly rule templates; rule names and availability change between content hub releases

For current available anomaly analytics templates, consult the Sentinel Content Hub and the `Anomaly` category in the Analytics rule template gallery — listing specific rule names here would become outdated as Microsoft revises the content hub.

5.7 DNS Security

DNS telemetry is necessary for C2 and tunneling detection. Key log sources:

- **Windows DNS Debug Log** — Full QNAME capture. Must be explicitly enabled on Windows DNS servers; not collected by default.
- **Zeek `dns.log`** — Structured DNS telemetry from network capture. Requires network tap or span port access.
- **RITA** — Automated DNS tunneling detection using subdomain entropy, bytes in/out, unique subdomain count. Open source; runs on Zeek output.
- **Infoblox Threat Defense** — Managed DNS with per-query anomaly scoring, DGA detection, NXDOMAIN flood. (Vendor product claim.)
- **Cisco Umbrella** — Cloud DNS resolver with global threat intelligence and anomalous query alerting. (Vendor product claim.)

Shannon Entropy for DNS Anomaly Detection:

Shannon entropy ($H = -\Sigma\ p(x) \cdot \log_2(p(x))$) measures the randomness of a string. Human-readable DNS subdomains (e.g., `mail`, `api`, `login`) typically have entropy below 3.5. Encoded data in DNS tunneling often produces entropy above 4.0.

The 4.0–4.5 threshold is a widely cited illustrative starting point, not a universal rule. CDN providers, some security vendors, and certain cloud services use high-entropy subdomain labels in legitimate traffic. Environment calibration against local baseline DNS traffic is required before deploying entropy-based alerting. Treat any threshold in this section as a hypothesis to validate, not a parameter to copy directly into production.

5.8 SaaS Audit Logs

SaaS audit logs are the primary — and in many intrusion scenarios the only — telemetry source for detecting activity that occurs entirely within cloud service layers.

Microsoft 365 Unified Audit Log — Key Operations:

Exchange:

- `MailItemsAccessed` — Requires Purview Audit Premium (E5 or add-on).
- `New-InboxRule` — Alert on any rule forwarding to external domain.
- `Add-MailboxPermission` — Mailbox delegation — alert for executive accounts.

SharePoint / OneDrive:

- `FileDownloaded` — Baseline per-user; alert on count spikes.
- `FileSyncDownloadedFull` — Full sync download — alert when sync target is unfamiliar.

Entra ID:

- `Add application` — New OAuth registration — scope-based alerting.
- `Consent to application` — OAuth consent — alert for `Mail.ReadWrite`, `Files.ReadWrite.All`.

Exchange admin:

- `Set-AdminAuditLogConfig` — Alert on any audit log disablement.

`OfficeActivity` in Sentinel (sourced from the M365 Unified Audit Log) does **not** contain a reliable byte-count field. `OfficeObjectId` is a document URL or path identifier, not a volume measure. Volume-based anomaly detection in M365 must use event count as the proxy metric. See Section 8.2 for a corrected query.

5.9 Detection Source Prioritization Matrix

Ratings reflect the effort required for a competent team starting from zero deployment and the detection fidelity achievable against documented adversary TTPs once fully operational. Implementation Effort covers licensing, configuration, tuning, and baseline establishment. Detection Fidelity reflects signal-to-noise ratio on targeted threat categories under realistic conditions — not theoretical maximum coverage.

Low effort — deploy first:

- **Windows Security Event Log (basic audit)** — Fidelity: Low–Medium. Coverage: account logon, privilege use, group changes. Prerequisite: default on domain-joined systems; limited without command-line capture.
- **Microsoft Defender for Endpoint** — Fidelity: High. Coverage: endpoint behavioral chains, EDR IOA/IOC, file and process telemetry. Prerequisite: MDE P2 license; Intune or GPO onboarding.
- **Microsoft Entra Sign-in Logs (P2)** — Fidelity: Medium–High. Coverage: password spray, impossible travel, MFA lifecycle anomalies, sign-in risk. Prerequisite: Entra ID P2 license; Sentinel connector for full field set.
- **M365 Unified Audit Log** — Fidelity: Medium. Coverage: SaaS exfiltration (count-based), inbox rule creation, OAuth app consent. Prerequisite: Purview Audit (Standard or Premium); MailItemsAccessed requires Premium.
- **Okta System Log** — Fidelity: Medium. Coverage: MFA factor changes, session anomalies, admin privilege grants. Prerequisite: Okta integration via SIEM connector.
- **AWS CloudTrail** — Fidelity: Medium–High. Coverage: IAM changes, API abuse, VM/storage creation by unusual principals. Prerequisite: CloudTrail enabled per region + SIEM ingestion.
- **Azure Activity Log** — Fidelity: Medium. Coverage: control-plane changes, VM creation, role assignments. Prerequisite: diagnostic settings → Log Analytics workspace.
- **IIS / Web Server Logs** — Fidelity: Medium. Coverage: rare URI access, webshell POST patterns, exploitation attempt signatures. Prerequisite: full field logging enabled (cs-uri-stem, cs-bytes, sc-status).

Medium effort:

- **Windows Security Event Log (advanced audit + command-line GPO)** — Fidelity: Medium–High. Coverage: process execution, lateral movement, DCSync, log clearing. Prerequisite: command-line GPO + SACL configuration for 4662.
- **Sysmon (with maintained config)** — Fidelity: High. Coverage: LSASS access, process injection, webshell writes, DNS by process, pipe creation. Prerequisite: deployment + maintained config file (SwiftOnSecurity or Hartong baseline).
- **DNS Resolver Logs (full QNAME)** — Fidelity: Medium. Coverage: DNS tunneling, DGA C2, domain rarity. Prerequisite: full QNAME capture — many resolvers log partial data by default.
- **NetFlow — perimeter only** — Fidelity: Low–Medium. Coverage: volumetric exfiltration, rare external destinations. Prerequisite: flow export from perimeter devices; east-west traffic not covered.

- **SaaS-native Audit Logs (Salesforce, Workday, Box, etc.)** — Fidelity: Medium. Coverage: insider/compromised account data access, bulk export, permission escalation. Prerequisite: per-platform enablement; ingestion into SIEM not always native.

High effort — mature infrastructure required:

- **Zeek / Corelight (network)** — Fidelity: High. Coverage: beaconing, JA3/JA3S C2 fingerprinting, protocol anomalies, lateral movement NetFlow. Prerequisite: span port or tap access to relevant network segments.
- **NetFlow — east-west (internal)** — Fidelity: Medium. Coverage: lateral movement scanning, SMB spread, internal C2 relay. Prerequisite: internal sensor placement or full span; significant infrastructure cost.
- **Linux auditd (syscall-level rules)** — Fidelity: High. Coverage: privilege escalation, capability abuse, kernel exploitation, process injection on Linux. Prerequisite: custom ruleset; high log volume requires aggressive filtering.

Reading the matrix: Sources with Low effort and Medium–High fidelity (MDE, Entra P2, CloudTrail) should be the first deployment targets. Sources with High effort and High fidelity (Zeek, east-west NetFlow, Linux auditd) deliver disproportionate value against sophisticated adversaries but require mature infrastructure. Low-effort, Low-fidelity sources (basic Windows audit) provide necessary context but should not anchor detection programs.

---

6. Credential-Based Attacks: Detection Engineering Deep Dive

6.1 Kerberoasting

What it is: An attacker with a valid domain user account requests Kerberos service tickets (TGS) for accounts with Service Principal Names (SPNs). The TGS ticket is encrypted with the service account's NTLM hash and can be cracked offline.

Windows Security Event 4769 — key fields:

- **`Ticket Encryption Type`** — Baseline: `0x12` (AES-256) or `0x11` (AES-128). Pattern: `0x17` (RC4-HMAC). Note: modern Windows DCs default to AES; RC4 is backward-compatible and still legitimately used by some legacy applications.

- **`Service Name`** — Baseline: machine accounts (`*$`) or well-known service names. Pattern: SPN-bearing service accounts — not machine accounts. Filter `ServiceName` not ending in `$`.
- **`Account Name`** — Baseline: service accounts, machines. Pattern: a regular user account requesting TGS for a service account.
- **`Ticket Options`** — Pattern: `0x40800010` is common in Kerberoasting tooling. Not definitive on its own.

Prerequisite: "Audit Kerberos Service Ticket Operations" (Success) must be enabled in Advanced Audit Policy → Account Logon on domain controllers.

Detection approach — heuristic analytic, not deterministic:

RC4 encryption type (0x17) in a Kerberos service ticket request is suspicious in environments where AES is enforced, but it is not universally anomalous. Legitimate sources of RC4 TGS requests include: legacy applications that do not support AES, service accounts whose `msDS-SupportedEncryptionTypes` attribute does not include AES, and specific compatibility configurations. The signal strength depends on how rigorously your environment enforces AES.

A volume pattern — a single account requesting RC4 TGS for many distinct service accounts in a short time window — is more indicative than a single request, but the appropriate threshold must be calibrated against your environment's legitimate RC4 usage before deployment. ADSecurity.org (Metcalf, 2017) [14] and MITRE ATT&CK T1558.003 both document this as a detection opportunity, framed as a starting point for investigation rather than a definitive indicator.

```
// HEURISTIC ANALYTIC — requires environment calibration before production deploymen
// Identify RC4 TGS requests from non-machine accounts targeting non-machine service
// Alert threshold (count) MUST be validated against legitimate RC4 usage in your en
index=wineventlog EventCode=4769
    TicketEncryptionType=0x17
    NOT ServiceName="*$"
    NOT AccountName="*$"
| bin _time span=15m
| stats dc(ServiceName) AS DistinctSPNs, values(ServiceName) AS SPNs
  by AccountName, ClientAddress, _time
| where DistinctSPNs > THRESHOLD
// THRESHOLD: start high (e.g., 5) and reduce after confirming no legitimate RC4 usa
// at that volume. Do not copy this value without calibration.
```

6.2 DCSync

What it is: An attacker with DS-Replication-Get-Changes and DS-Replication-Get-Changes-All directory permissions mimics Active Directory replication to extract NTLM hashes and Kerberos keys for any domain account, including `krbtgt`. Implemented in Mimikatz (`lsadump::dcsync`) and Impacket's `secretsdump.py`.

Windows Security Event 4662 — key fields:

Event 4662 requires both: (1) "Directory Service Access" audit policy enabled (DS Access → Directory Service Access, Success) **and** (2) a SACL explicitly configured on the domain naming context (NC) root object granting `SYSTEM` principal audit rights for the relevant GUIDs. Neither is configured by default.

- **`SubjectUserName`** — Legitimate: domain controller machine account (`DC01$`) or `NT AUTHORITY\SYSTEM`. DCSync pattern: a regular user or admin account — not a machine account. This is the primary discriminator.
- **`ObjectType`** — Both legitimate and DCSync: `%{19195a5b-6da0-11d0-afd3-00c04fd930c9}` (domainDNS object).
- **`Properties` (GUIDs)** — Legitimate: replication GUIDs from DC machine accounts. DCSync pattern: `{1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}` (DS-Replication-Get-Changes) and `{1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}` (DS-Replication-Get-Changes-All) from a non-machine account. Third GUID `{89e95b76-444d-4c62-991a-0facbeda640c}` applies to filtered-set replication (RODC).
- **`AccessMask`** — Legitimate: `0x100` for DS-Replication-Get-Changes. DCSync: same value, but from a non-DC source. Verifying the access mask narrows the query.

Legitimate false-positive sources that must be allowlisted:
- Microsoft Entra Connect (formerly Azure AD Connect) performs DS-Replication-Get-Changes from a dedicated sync account — this is legitimate replication that will fire the detection if the account is not allowlisted
- Any backup solution or identity management product with delegated replication permissions
- Purpose-built identity audit tools

```
// HEURISTIC ANALYTIC — requires allowlisting of legitimate replication accounts
// before production deployment. Review all matches manually first.
index=wineventlog EventCode=4662
    ObjectType="%{19195a5b-6da0-11d0-afd3-00c04fd930c9}"
    Properties="*1131f6aa*"
```

```
    Properties="*1131f6ad*"
    NOT SubjectUserName="*$"          // exclude machine accounts (DCs)
    NOT SubjectUserName IN ("MSOL_*", "AADConnect*")  // allowlist Entra Connect acc
    // Add additional allowlist entries for any tool with legitimate replication rig
| table _time, SubjectUserName, SubjectDomainName, IpAddress
```

This query surfaces a high-confidence but not infallible signal. Review all results before automating escalation, and maintain the allowlist as replication service accounts change.

6.3 Pass-the-Hash

What it is: An attacker uses a captured NTLM hash to authenticate to a remote system without the cleartext password. The hash is presented directly to NTLM authentication.

Windows Security Event 4624 — heuristic field combination:

The combination of fields below is associated with Pass-the-Hash (PTH) in detection engineering literature (Binary Defense [16], CyberArk research). It is a **heuristic indicator**, not a deterministic signature. Legitimate NTLM network logons from some application configurations, guest access scenarios, and certain service accounts can produce similar field combinations.

- `LogonType` = `3` (Network) — Also present in legitimate network logons.
- `LogonProcessName` = `NtLmSsP` — Indicates NTLM path; legitimate domain logons typically show `Kerberos`.
- `AuthenticationPackageName` = `NTLM` — Confirms NTLM authentication.
- `SubjectUserSid` = `S-1-0-0` (NULL SID) — Indicates no prior interactive logon session on the source; also appears in some anonymous and service-account configurations.
- `KeyLength` = `0` — Associated with PTH; also present in some session types.

The core correlation: PTH logons typically occur without a preceding interactive (Type 2) or remote-interactive (Type 10) logon for the same `TargetUserName` on the same source host. Binary Defense's analysis [16] documents this correlation as the most reliable discriminator, while explicitly noting it is not foolproof.

> ***Fragility caveat:*** *This heuristic is fragile. In environments with significant residual NTLM usage, legacy application tiers, printer and multi-function device SMB access, backup agents, inter-forest NTLM paths, or network scanners, the Null-SID + NtLmSsP + LogonType 3 combination may produce*

> *hundreds of benign matches per day. The analytic is operationally useful only in environments that have substantially deprecated NTLM, OR when combined with a destination-host risk-tier filter (domain controllers, regulated-data file servers). Do not deploy as written without such scoping.*

```
// HEURISTIC ANALYTIC — validate against environment baseline before alerting
// This combination is characteristic of PTH but not exclusive to it
// Correlate with host and user context before escalating
index=wineventlog EventCode=4624
    LogonType=3
    LogonProcessName=NtLmSsP
    AuthenticationPackageName=NTLM
    SubjectUserSid="S-1-0-0"
    NOT TargetUserName="*$"   // exclude machine account logons
| stats count by TargetUserName, WorkstationName, IpAddress
// Enrich: does TargetUserName have a prior Type 2 logon from WorkstationName?
// Absence of prior interactive logon increases confidence
```

Highest-value targets for correlation: PTH against domain controllers (Event 4624 on the DC itself) or file servers housing sensitive data; PTH from workstations to other workstations is lower priority in most environments.

6.4 LSASS Credential Dumping (Sysmon Event 10)

What it is: Tools such as Mimikatz, ProcDump, or custom loaders access LSASS (Local Security Authority Subsystem Service) memory to extract NTLM hashes, Kerberos tickets, or WDigest credentials.

Sysmon Event 10 — ProcessAccess for LSASS:

- **`TargetImage`** = `lsass.exe` — Scope this rule exclusively to LSASS as target.
- **`GrantedAccess`** — Alert on: `0x1010` (PROCESS_VM_READ + PROCESS_QUERY_INFORMATION — Mimikatz sekurlsa mask); `0x1410` (adds PROCESS_DUP_HANDLE); `0x0820` (injection-style mask). Other masks (e.g., `0x1fffff` — all access) should also be reviewed.
- **`SourceImage`** — Any process not on the environment-specific allowlist. The allowlist is environment-dependent; see allowlist guidance below.
- **`CallTrace`** — Contains `UNKNOWN` module: indicates injected code as the caller, not a registered DLL.

Allowlist guidance: The following process categories legitimately access LSASS and must be excluded, verified per your environment:
- Windows Defender / MsMpEng.exe
- `csrss.exe`, `werfault.exe`, `lsm.exe`
- EDR agent processes (confirm exact names with your EDR vendor)
- AV/EPP processes (confirm exact names with your security tool vendor)
- `taskmgr.exe` from explicitly privileged sessions

Do not build a static allowlist from documentation alone — profile your environment's legitimate LSASS access pattern before deploying this rule.

---

7. How Attackers Suppress Anomaly Visibility

Advanced threat actors apply documented techniques to reduce their anomaly footprint.

Distribute the signal. Midnight Blizzard spread password spray failures across thousands of residential proxy IPs, ensuring no single IP or ASN exceeded per-tenant alert thresholds. [Documented — Microsoft MSTIC [4]] The same principle applies to exfiltration — many small transfers across many days can individually fall below volumetric thresholds, while the aggregate is significant.

Use valid credentials and legitimate tools. Volt Typhoon's use of `ntdsutil`, `netsh portproxy`, `wevtutil`, and other native Windows tools means the executed processes are identical to those a legitimate administrator would run. CISA's advisory explicitly acknowledges this and warns against attributing those commands to malicious activity without corroborating evidence. [Documented — CISA AA24-038A [10]] Detection depends on command-line argument combinations, execution context (which user, on which host), and correlation with other signals.

Execute in-process. Microsoft documented that actors deployed malicious IIS native modules that execute within `w3wp.exe` address space, bypassing child-process anomaly detection. [Documented — Microsoft MSTIC [5]] SUNBURST's TEARDROP loaded Cobalt Strike entirely in memory, generating no on-disk executable artefacts. [Documented — Mandiant [3]]

Exploit logging gaps. CISA and NSA document that default Windows configurations omit command-line arguments in process creation events, WMI event details, and PowerShell script block content. [Documented — CISA/NSA [11]] Actors with knowledge of default configurations can operate within the gap between what happens and what is recorded.

Mimic business rhythm. Microsoft's Storm-0558 analysis included actor activity heatmaps showing operations during business hours consistent with the actor's time zone — temporal anomaly logic that flags off-hours activity would not have fired. [Documented — Microsoft MSTIC [4]] SUNBURST's 12–14 day dormancy period was designed to separate installation from C2 activation in any investigation timeline. [Documented — Mandiant [3]]

Use SaaS-native functionality for exfiltration. UNC3944's use of Airbyte and Fivetran for exfiltration generated no signals in perimeter firewall egress logs or EDR process telemetry, because the data movement occurred within SaaS provider infrastructure after the connector was established. Detection required the SaaS platform's own audit log recording the connector creation and data transfer. [Documented — Mandiant [8]]

Absorb into baseline through slow operation. NIST SP 800-94 documented that "malicious activity can be incorporated into a normal profile" if the training window is contaminated. [Documented [1]] Anomaly systems that retrain on recent data will incorporate slow, persistent attacker behaviour into the baseline if the actor operates for weeks before the training window refreshes.

---

8. Detection Engineering Patterns and Logic Examples

8.1 Four Core Design Patterns

Pattern 1 — Rarity-in-Role *(heuristic analytic)*
Detect an event that is rare for the specific user, host class, or application tier. The baseline denominator is the peer group, not the estate. `ntdsutil` on a developer workstation is anomalous; `ntdsutil` on a domain controller during a backup window is expected.

Pattern 2 — Rate-Plus-Shape *(heuristic analytic)*
Combine event count with timing distribution, source diversity, or target spread. A hundred authentication failures from one IP is a rate anomaly. The same count distributed across one hundred IPs, each targeting a different account, is a shape anomaly undetectable by per-IP rate limiting.

Pattern 3 — State-Change Gating *(deterministic rule with scope constraint)*
Alert on control-plane changes that rarely occur legitimately and materially alter trust or exposure. New OAuth app registration with mail-access scope; new inbox forwarding rule to external domain; new VM created by a service principal. These are first-occurrence or infrequent-occurrence events where a threshold of one — scoped to a specific object class — produces acceptable precision without a statistical baseline.

Pattern 4 — Hybrid: Deterministic Gate then Anomaly Score *(combination)*

Apply anomaly scoring only after filtering on a high-risk object class. Score app-consent anomalies only when the scope includes `Mail.ReadWrite` or `Files.ReadWrite.All`. Score VM-creation anomalies only when the initiating principal is a service principal or a recently-created user account. Score LSASS access anomalies only when `GrantedAccess` matches specific malicious masks. This narrows the baseline problem before the statistical model runs, improving precision without sacrificing recall on the targeted class.

8.2 Detection Logic Examples

Each example is labelled with its analytical type.

Distributed Password Spray — Rate and Shape

Type: Heuristic analytic. Thresholds are illustrative starting points; calibrate per tenant before production deployment.

```
// Sentinel / KQL
// Detects: high failure spread across accounts and IPs, followed by any
// successful sign-in in the same or subsequent time window.
// Result: candidate accounts to investigate, not confirmed compromises.
let lookback       = 60m;
let spray_window   = 15m;
let min_accounts   = 15;   // tune per tenant — lower in small tenants
let min_ips        = 5;    // tune per tenant

let spray_periods =
    SigninLogs
    | where TimeGenerated > ago(lookback)
    | where ResultType !in ("0", "50140")   // exclude success and "Stay signed in"
    | summarize
        FailedAccounts = dcount(UserPrincipalName),
        SourceIPs      = dcount(IPAddress)
      by bin(TimeGenerated, spray_window)
    | where FailedAccounts >= min_accounts and SourceIPs >= min_ips
    | extend WindowStart = TimeGenerated,
             WindowEnd   = TimeGenerated + 30m;

SigninLogs
| where TimeGenerated > ago(lookback)
```

```
| where ResultType == "0"    // successes only
| where isnotempty(UserPrincipalName)
| join kind=inner spray_periods
    on $left.TimeGenerated between ($right.WindowStart .. $right.WindowEnd)
| project TimeGenerated, UserPrincipalName, IPAddress, Location,
          AppDisplayName, RiskLevelDuringSignIn, AuthenticationRequirement
| order by TimeGenerated desc
```

Kerberoasting — RC4 TGS Volume

Type: Heuristic analytic. The count threshold must be calibrated against local RC4 usage before deployment.

```
index=wineventlog EventCode=4769
    TicketEncryptionType=0x17
    NOT ServiceName="*$"
    NOT AccountName="*$"
| bin _time span=15m
| stats dc(ServiceName) AS DistinctSPNs, values(ServiceName) AS SPNs
  by AccountName, ClientAddress, _time
| where DistinctSPNs > THRESHOLD
| table _time, AccountName, ClientAddress, DistinctSPNs, SPNs
```

DCSync — Replication GUIDs from Non-DC Account

Type: Heuristic analytic with deterministic field match. Requires SACL configuration and allowlisting of legitimate replication accounts (see Section 6.2).

```
index=wineventlog EventCode=4662
    ObjectType="%{19195a5b-6da0-11d0-afd3-00c04fd930c9}"
    Properties="*1131f6aa*"
    Properties="*1131f6ad*"
    NOT SubjectUserName="*$"
| table _time, SubjectUserName, SubjectDomainName, IpAddress
// Review all results against allowlisted replication service accounts
// before automated escalation
```

Pass-the-Hash — NTLM Network Logon Heuristic

Type: Heuristic analytic. This field combination is characteristic but not exclusive to PTH (see Section 6.3 for false positive sources).

```
index=wineventlog EventCode=4624
    LogonType=3
    LogonProcessName=NtLmSsP
    AuthenticationPackageName=NTLM
    SubjectUserSid="S-1-0-0"
    NOT TargetUserName="*$"
| stats count by TargetUserName, WorkstationName, IpAddress, ComputerName
| sort - count
```

LSASS Credential Access — Sysmon Event 10

Type: Heuristic analytic. Allowlist must be built from your environment's observed legitimate LSASS callers.

```
index=sysmon EventCode=10
    TargetImage="*lsass.exe"
    (GrantedAccess=0x1010 OR GrantedAccess=0x1410 OR GrantedAccess=0x0820
     OR GrantedAccess=0x1fffff)
    (CallTrace="*UNKNOWN*" OR CallTrace!="*\\Windows\\*")
    NOT SourceImage IN (
        "C:\\Program Files\\Windows Defender\\MsMpEng.exe",
        "C:\\Windows\\System32\\csrss.exe",
        "C:\\Windows\\System32\\werfault.exe"
        // Add EDR agent and AV paths specific to your environment
    )
| table _time, SourceImage, GrantedAccess, CallTrace, Computer
```

Web-Server Process Spawning Shell Interpreter

Type: Deterministic rule — no statistical baseline required for the core parent-child relationship. Scope to production internet-facing servers to reduce false positives from development environments.

```
// Sentinel / KQL — DeviceProcessEvents (MDE)
// DETERMINISTIC RULE for production internet-facing IIS / Exchange servers
```

```
DeviceProcessEvents
| where InitiatingProcessFileName in~ (
    "w3wp.exe", "UMWorkerProcess.exe", "httpd.exe", "nginx.exe")
  and FileName in~ (
    "cmd.exe", "powershell.exe", "wscript.exe",
    "cscript.exe", "mshta.exe", "bitsadmin.exe")
| where DeviceName in (known_internet_facing_servers)  // scope to server list
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName,
          ProcessCommandLine, InitiatingProcessCommandLine
```

DNS Tunneling — Shannon Entropy on Subdomain

Type: Illustrative pseudocode. Not production-ready as written; shows the logic for integration into a Zeek scripted detection or SIEM enrichment function.

```
# ILLUSTRATIVE PSEUDOCODE — not directly executable
# Integrate entropy scoring into Zeek scripted detection or SIEM enrichment
import math
from urllib.parse import urlparse

def shannon_entropy(s: str) -> float:
    if not s:
        return 0.0
    freq = {}
    for c in s:
        freq[c] = freq.get(c, 0) + 1
    return -sum((f / len(s)) * math.log2(f / len(s)) for f in freq.values())

def extract_subdomain(fqdn: str) -> str:
    """Return subdomain portion (everything left of registered domain + TLD)."""
    parts = fqdn.rstrip('.').split('.')
    # Naive: treat last two labels as registered domain + TLD
    # Use a public suffix list library for accurate extraction in production
    return '.'.join(parts[:-2]) if len(parts) > 2 else ''

def is_suspicious_dns(fqdn: str, query_type: str) -> bool:
    subdomain = extract_subdomain(fqdn)
    entropy   = shannon_entropy(subdomain)
    # Thresholds below are illustrative starting points.
    # Calibrate against local DNS baseline before deployment.
```

```
    # CDN subdomains and some security-vendor domains also exceed these values.
    return (
        entropy > 4.0 or
        len(subdomain) > 30 or
        (query_type in ('TXT', 'NULL') and entropy > 3.5)
    )
```

SaaS Bulk Download Anomaly (M365 SharePoint / OneDrive)

Type: Heuristic anomaly model. Count-based — M365 Unified Audit Log does not provide reliable byte-count fields in OfficeActivity. Thresholds are illustrative starting points.

```
// Sentinel / KQL — OfficeActivity (sourced from M365 Unified Audit Log)
// NOTE: OfficeObjectId is a document URL identifier, not a byte-count field.
// This analytic uses download event count as the volume proxy.
// Thresholds (min_baseline_days, z_threshold) require per-environment tuning.
let min_baseline_days = 30;
let alert_window_days = 1;
let z_threshold = 4.0;   // illustrative — tune after observing score distribution

let baseline =
    OfficeActivity
    | where TimeGenerated between (
        ago(toduration(tostring(min_baseline_days + alert_window_days) + "d"))
        .. ago(1d))
    | where Operation in ("FileDownloaded", "FileSyncDownloadedFull")
    | summarize DailyCount = count()
      by UserId, bin(TimeGenerated, 1d)
    | summarize
        BaselineAvg  = avg(DailyCount),
        BaselineStdev = stdev(DailyCount)
      by UserId;

OfficeActivity
| where TimeGenerated > ago(1d)
| where Operation in ("FileDownloaded", "FileSyncDownloadedFull")
| summarize TodayCount = count() by UserId
| join kind=inner baseline on UserId
| where BaselineStdev > 0
| extend ZScore = (TodayCount - BaselineAvg) / BaselineStdev
```

```
| where ZScore > z_threshold
| project UserId, TodayCount, BaselineAvg = round(BaselineAvg,1),
          BaselineStdev = round(BaselineStdev,1), ZScore = round(ZScore,1)
| order by ZScore desc
```

---

9. Implementation Guidance

9.1 Instrument Before Modelling

No anomaly programme compensates for missing telemetry. Before deploying any anomaly model, confirm:

- **Process creation with command-line** (Event 4688 or Sysmon Event 1): requires both the audit subcategory and the GPO `Include command line in process creation events`. Without command-line content, LOTL detection is severely limited.
- **Sysmon deployed** with a maintained configuration file covering at minimum Events 1, 3, 7, 8, 10, 11, 13, 17, 22.
- **PowerShell logging**: Module Logging (Event 4103) and Script Block Logging (Event 4104) — not enabled by default; require GPO configuration. Transcription to a centralised network path is also recommended.
- **DNS query logging**: Windows DNS debug log enabled, or Zeek deployed on DNS traffic.
- **SaaS audit logging**: enabled and forwarded to SIEM for all production SaaS platforms. For Microsoft 365, verify that `MailItemsAccessed` auditing is active (requires Purview Audit Premium).
- **Cloud audit logs** (CloudTrail, Azure Activity Log, GCP Audit): forwarded to SIEM with sufficient retention.
- **IdP logs** (Entra sign-in, Okta System Log): fully ingested with all fields, not sampled.

9.2 Prioritise by Baseline Stability

Deploy analytics in order of baseline tightness and signal stability:

1. **Deterministic or near-deterministic rules first** — webshell parent-child lineage (`w3wp.exe` → `cmd.exe` on production internet-facing servers), VSS shadow copy deletion (`vssadmin delete shadows` on workstations — near-zero legitimate prevalence). No baseline needed.

2. **High-signal heuristics (require scope and allowlisting)** — `ADMIN$` write from non-admin workstations (FP sources: admin jump hosts, software deployment tooling, IR tools); Cobalt Strike default named-pipe patterns (FP sources: legitimate security tooling using similar pipe name conventions; absence does not exclude Cobalt Strike when Malleable C2 is in use).
3. **Domain controllers** — Kerberoasting (Event 4769 RC4, calibrated threshold), DCSync (Event 4662 with SACL, allowlisted), LSASS access (Sysmon Event 10, allowlisted)
4. **Identity providers** — MFA lifecycle changes for privileged accounts, unfamiliar sign-in properties, app consent with high-risk scopes
5. **Cloud control planes** — VM creation by unusual principals, IAM role grants, storage policy changes
6. **SaaS audit** — bulk download count anomaly, inbox forwarding rule creation, OAuth app registration
7. **Network** — DNS entropy analytics, beaconing detection (RITA or NDR platform)
8. **Estate-wide UEBA** — only after the above are producing tuned results

9.3 Baseline by Role, Not by Estate

A finance analyst, an Exchange server, a Kubernetes API server, and a developer workstation share no meaningful behavioural baseline. Estate-wide thresholds produce signals too loose for privileged infrastructure and too tight for dynamic environments. The correct denominator is the peer group.

Minimum useful peer group definitions:
- **Users**: department + job function (IT admin / developer / finance / HR / executive)
- **Hosts**: role (DC / Exchange / IIS / developer workstation / build server) + network segment
- **Applications**: production / staging / dev + data classification tier

9.4 Accumulate Weak Signals via Entity Risk Scoring

No single anomaly should generate an investigation ticket in most environments. Accumulate correlated weak signals against the same entity over a time window.

Illustrative composite triggers (point values are examples only — calibrate to your environment's signal density):

- **Identity attack:** MFA reset for privileged user → unfamiliar sign-in within 1 hour → new OAuth app consent with mail scope → inbox rule creation.
- **Endpoint post-exploitation:** ADFind execution → LDAP query spike → ADMIN$ access → new service installation.

- **Cloud persistence:** Service principal creating VM → API key creation → outbound data to new cloud storage destination.

9.5 Validate with Purple-Team Exercises

Anomaly detection degrades silently through parser drift, schema changes, exception list growth, and baseline drift. Schedule quarterly validation:

- Password spray simulation against test accounts — verify Event 4625 rate/spread detection
- Kerberoasting against test SPNs with RC4-only service account — verify Event 4769 detection fires at configured threshold
- DCSync from lab workstation against lab DC with SACL configured — verify Event 4662 detection fires and allowlist is functioning
- Webshell in test IIS environment — verify Sysmon Event 11 and parent-child detection
- Bulk SharePoint download from test site — verify count-based anomaly detection
- DNS tunneling simulation (dnscat2 in isolated lab) — verify entropy detection
- Rclone execution against test endpoint — verify rare-process detection

After each exercise, verify that the detection fired and that the alert contained enough context for an analyst to act without additional queries.

---

10. Conclusion

The hypothesis that malicious activity creates detectable anomaly patterns is substantially true but operationally bounded. The evidence from documented campaigns confirms it in specific contexts:

- SUNBURST created collective DNS anomalies — encoded subdomains with measurable entropy above baseline, a dormancy period, and machine-generated timing — detectable with full DNS telemetry and entropy analytics.
- HAFNIUM created a parent-child execution chain (`w3wp.exe` → `cmd.exe`) with near-zero legitimate prevalence on production Exchange servers — detectable with Sysmon or EDR process lineage rules scoped to internet-facing hosts.
- Conti produced a cascade of signals across multiple phases — ADFind rare-process execution, ADMIN$ share access, PsExec service installation, VSS deletion, Defender disable — each

individually detectable with properly configured Windows audit logging and Sysmon.

- APT34's DNS tunneling produced measurable anomalies in query entropy, subdomain length, and TXT record usage — detectable with complete DNS telemetry and entropy scoring.

The failure modes are equally documented. Kerberoasting, DCSync, and Pass-the-Hash each produce structured patterns in authentication logs that support targeted heuristic analytics, but none is fully deterministic — each requires environment-specific calibration, allowlisting of legitimate processes or accounts, and correlation with additional context before automated escalation. Treating these as "configure event ID, check field value, alert" is an oversimplification that produces either unacceptable false positive rates or missed detections.

Volt Typhoon demonstrated that LOTL techniques plus valid credentials plus SOHO proxy infrastructure can suppress most anomaly signals to the level of contextual command-line analysis — detectable only with command-line logging enabled and allowlisted-command baseline in place. Midnight Blizzard demonstrated that distributed spray across residential proxies defeats per-tenant rate analytics. UNC3944 demonstrated that SaaS-native exfiltration via connected apps generates no signals in environments without SaaS audit log collection.

The "Anomaly Paradox" — that the approach best suited to catching novel activity also generates the highest false positive rates — is **mitigated but not eliminated** by hybrid analytics: anomaly logic applied to tightly scoped, role-normalised, enriched data, gated by deterministic conditions, and correlated into entity risk scores. This reduces the base-rate problem but does not resolve it. Managing the residual false positive burden requires ongoing tuning, clear escalation criteria, and analyst training to distinguish anomaly scores from confirmed verdicts.

The practical priorities for detection engineering:

1. **Telemetry before analytics** — command-line process logging, Sysmon, SaaS audit, and cloud audit must be in place before anomaly models are deployed.
2. **Deterministic rules for structurally unambiguous patterns** — webshell parent-child, named-pipe IOCs, VSS deletion commands, new-account creation by web-worker processes.
3. **Calibrated heuristics for high-value signals** — Kerberoasting RC4 volume, DCSync GUIDs with allowlisting, NTLM Null-SID network logons in context.
4. **Anomaly modelling for scale-dependent signals** — volumetric exfiltration, DNS entropy, bulk SaaS download counts.
5. **Provider-native detections for cross-tenant visibility** — Entra Identity Protection's Password spray detection provides coverage that tenant-local rate analytics structurally cannot replicate.

6. **SaaS and cloud as primary telemetry domains** — intrusions by Midnight Blizzard, Storm-0558, and UNC3944 occurred primarily in identity and SaaS layers; network and endpoint monitoring alone would not have surfaced them.

---

11. References

[1] National Institute of Standards and Technology. *Guide to Intrusion Detection and Prevention Systems (IDPS)*. NIST Special Publication 800-94. February 2007. https://csrc.nist.gov/pubs/sp/800/94/final

[2] Chandola, V., Banerjee, A., and Kumar, V. "Anomaly Detection: A Survey." *ACM Computing Surveys*, 41(3), Article 15, July 2009. https://dl.acm.org/doi/10.1145/1541880.1541882

[3] Mandiant (FireEye). "SUNBURST Additional Technical Details." December 2020. https://www.mandiant.com/resources/sunburst-additional-technical-details

[4] Microsoft Security Response Center / Microsoft Threat Intelligence. "Midnight Blizzard: Guidance for Responders on Nation-State Attack." January 2024. https://www.microsoft.com/en-us/security/blog/2024/01/25/midnight-blizzard-guidance-for-responders-on-nation-state-attack/

[5] Microsoft Security Response Center. "HAFNIUM Targeting Exchange Servers with 0-Day Exploits." March 2021. https://www.microsoft.com/en-us/security/blog/2021/03/02/hafnium-targeting-exchange-servers/

[6] [VERIFICATION NEEDED] The in-text citation [6] supports the Storm-1283 OAuth application + Azure VM cryptomining narrative in Section 4.8. A specific Microsoft Security Blog post covering Storm-1283 by that designation has not been independently verified by the author; search the Microsoft Threat Intelligence Blog for "Storm-1283" for the current authoritative source. As a nearest generic substitute: Microsoft Threat Intelligence. "Token tactics: How to prevent, detect, and respond to cloud token theft." November 2022. https://www.microsoft.com/en-us/security/blog/2022/11/16/token-tactics-how-to-prevent-detect-and-respond-to-cloud-token-theft/ — *Note: this source covers OAuth token abuse generally and does not specifically report Storm-1283.*

[7] Mandiant. "Responding to Microsoft Exchange Server Zero-Day Vulnerabilities." March 2021. https://cloud.google.com/blog/topics/threat-intelligence/responding-to-exchange-server-zero-days

[8] Mandiant. "UNC3944 Targets SaaS Applications." Google Cloud Security Blog, 2023. https://cloud.google.com/blog/topics/threat-intelligence/unc3944-targets-saas-applications

[9] Mandiant. *M-Trends 2025*. Google Cloud Security, 2025. https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2025

[10] CISA, NSA, FBI, and partner agencies. "People's Republic of China State-Sponsored Cyber Actor Living off the Land to Evade Detection." Advisory AA24-038A. February 2024. https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-038a

[11] CISA and NSA. "Guide to Securing Microsoft Windows 10 and Windows 11 Audit and Monitoring Events." 2024. https://www.cisa.gov/resources-tools/resources/guide-securing-microsoft-windows-10-and-windows-11-audit-and-monitoring-events

[12] Australian Cyber Security Centre. "Detecting and Mitigating Active Directory Compromises." 2023. https://www.cyber.gov.au/resources-business-and-government/maintaining-devices-and-systems/system-hardening-and-administration/system-administration/detecting-and-mitigating-active-directory-compromises

[13] The DFIR Report. "BazarCall to Conti Ransomware via Trickbot and Cobalt Strike." August 2021. https://thedfirreport.com/2021/08/01/bazarcall-to-conti-ransomware-via-trickbot-and-cobalt-strike/

[14] Metcalf, S. "Detecting Kerberoasting Activity." ADSecurity.org, 2017. https://adsecurity.org/?p=3458

[15] Black Lantern Security. "Detecting DCSync." 2022. https://blog.blacklanternsecurity.com/p/detecting-dcsync

[16] Binary Defense. "Reliably Detecting Pass the Hash Through Event Log Analysis." 2021. https://blog.binarydefense.com/reliably-detecting-pass-the-hash-through-event-log-analysis

[17] Palo Alto Unit 42. "OilRig Targets Middle Eastern Telecommunications Organization and Adds Novel C2 Channel with QUADAGENT." 2018. https://unit42.paloaltonetworks.com/unit42-oilrig-targets-middle-eastern-telecommunications-organization/

[18] CISA. "ALPHV Blackcat Ransomware." Advisory AA23-353A. December 2023. https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-353a

[19] CISA. "CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability." Advisory AA23-158A. June 2023. https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a

[20] CISA. "Impacket and Exfiltration Tool Used to Steal Sensitive Information from Defense Industrial Base Organization." Advisory AA22-277A. October 2022. https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-277a

[21] CrowdStrike. "Understanding Indicators of Attack: The Power of Event Stream Processing." CrowdStrike Blog, 2023. https://www.crowdstrike.com/en-us/blog/understanding-indicators-attack-ioas-power-event-stream-processing-crowdstrike-falcon/

[22] Vectra AI. *Cognito Platform — AI-Driven Threat Detection and Response*. Product documentation, 2024. https://www.vectra.ai/products/cognito-platform *(Vendor product documentation — detection claims are not independently benchmarked)*

[23] Amazon Web Services. "GuardDuty Finding Types." AWS Documentation, 2024. https://docs.aws.amazon.com/guardduty/latest/ug/guardduty_finding-types-active.html

[24] Microsoft. "Work with Anomaly Detection Analytics Rules in Microsoft Sentinel." Microsoft Learn, 2024. https://learn.microsoft.com/en-us/azure/sentinel/work-with-anomaly-rules

[25] National Security Agency and Australian Signals Directorate. "Detect and Prevent Web Shell Malware." April 2020. https://www.nsa.gov/Press-Room/News-Highlights/Article/Article/2159615/detect-and-prevent-web-shell-malware/

↑ Back to top